



Network Security Group Project Report

Submitted by: Team 4

Name	Student ID
Muhd Wafiyuddin Bin Abdul Rahman	*****
Mohamed Shifann Bin Mohamed Ismail	*****
Muhammad Saad Bin Hadi	*****
Adil Amr Bin Qamaruzzaman	*****
Muhammad Nafis Bin Mohamed Idris	*****
Muhammed Abdillah Bin Zainul Abideen	*****

Table of Contents

Introduction.....	4
Network Requirements	4
Scope & operating context.....	6
Security design stance.....	7
Topology.....	7
Configuration.....	7
Addressing Table without Management.....	7
Addressing Table for Out-Of-Band (OOB).....	13
Security Design (Defence-In-Depth)	15
Layer 2 Switch (Access switches/layer).....	15
1. Introduction.....	15
2. Port Security	16
3. DHCP Snooping (with Rate Limiting) and Dynamic ARP Inspection (DAI).....	17
4. Spanning Tree Protocol (STP) Security	18
5. Errdisable Recovery and Violation Handling.....	20
6. VLAN Segmentation and Unused Port Shutdown	20
7. Secure Remote Access (SSH).....	21
8. Control Plane Policing (CoPP).....	23
9. User Authentication and Access Control	23
10. Centralised AAA with TACACS+ and Local Fallback.....	24
11. Role-Based Command Control (Custom Privilege Levels).....	25
12. Login Success Logging and Centralised Syslog	26
13. NTP for Time Synchronisation	27
14. Management Plane Isolation (Mgmt VRF & Management VLAN).....	28
15. IP Source Guard (IP Verify Source MAC-Check	29
16. Trunk & Uplink Hardening.....	29
17. Conclusion	30
Layer 3 Switch (Distribution Switches/Layer).....	32
1. Introduction.....	32
2. Centralised AAA with TACACS+ and Local Fallback.....	33
3. Local Admin Account with Encrypted Secret.....	34
4. SSH-Only Remote Management with Session Controls	34
5. Console Access Protected by AAA.....	35
6. Management VRF Separation	36
7. Login Success Logging.....	36
8. Centralised Syslog	37
9. NetFlow for Traffic Visibility	38
10. NTP with Event Logging.....	39
11. Control-Plane Protection (CoPP / CPP).....	40

12. Layer 2 Trunk Hardening and STP Protection	41
13. OSPF Hardening with Passive Interfaces.....	43
14. Redundant Gateways Using HSRP	44
15. Inter-VLAN Access Control for R&D Isolation (ACL RND_ISOLATION)	45
16. Centralised DHCP via IP Helper (DHCP Relay).....	46
17. High Availability Core Design with SSO & Layer 3 Port-Channel	47
18. Conclusion	49
Firewall	50
1) Overview	50
2) Interface Zoning & Security Levels.....	50
3) NAT: Addressing, Publishing, and Egress	51
4) Access Control (ACLs) – Inbound Policy	52
5) Stateful Inspection (MPF).....	53
6) Dynamic Routing (OSPF).....	54
7) Management Plane Security	55
8) Network Services & Hygiene	55
9) Routing & Defaults.....	56
Router (Edge Layer)	58
1. Introduction.....	58
2. Edge Roles, Interfaces & Unused Port Hardening	58
3. Secure Public Exposure via Static NAT and PAT.....	60
3. Internet Edge ACL to Block SSH to Public Servers	61
4. Routing & Forwarding Hygiene.....	62
5. Traffic Visibility with NetFlow on Inside, Outside, and Management Links.....	63
6. SSH & AAA-Based Administrative Access	64
7. Management VRF with Centralised Logging & Time Synchronisation.....	66
8. Conclusion	67
DHCP Server	68
1. Introduction.....	68
2. DHCP Scope Protection with Excluded Addresses.....	69
2. Authoritative DHCP Pools with Trusted Internal DNS.....	70
3. Interface Roles, Management VRF & Unused Port Hardening.....	71
4. Secure Remote Management (SSH, Local Auth).....	72
5. Centralised Logging and Time Synchronisation	72
5. Traffic Visibility with NetFlow on Service and Management Links.....	73
6. Conclusion	74
SSH.....	75
User login	75
Step 1.....	75
Step 2.....	76
Step 3.....	76

Special Implementation.....	77
1. VPN.....	77
Setup	77
Step 1 – Update your system.....	77
Step 2 – Installing a WireGuard VPN server on Ubuntu 20.04 LTS.....	77
Step 3 – Configuring WireGuard server.....	77
Step 4 – Enable and start WireGuard service	81
Step 5 – Wireguard VPN client configuration.....	81
Step 6 – Verification.....	83
Step 7 – Download wireguard	83
Jumphost SSH Steps.....	86
2. Netflow.....	88
Credentials	90

Introduction

This report designs and validates a secure enterprise LAN for Qubit, a quantum computing startup, using a hierarchical architecture and defence-in-depth, with an out-of-band (OOB) management plane and network security monitoring (NSM). The build must support segmented research and development networks with time-based internet access, a secure network for departments, core business operations, and a small DMZ, then be proven via a structured validation plan.

Network Requirements

The network must support multiple departments, computer labs, and essential IT services. The infrastructure requirements are detailed in the tables below:

1. Computer Labs

Lab Type	Number of Labs	Computer per Lab	Total Computers
Lab-A	1	10	10
Lab-B	1	10	10
Lab-C	1	10	10

Table 1: Computer Labs

2. Staff Workstations

Office	Roles	Number of Computers
IT Department	Network Manager	1
	Network Engineers	2
HR Department	Manager	1
	Admin Staff	2
Finance Department	Manager	1
	Accountants	2
Total Workstations	-	9

Table 2: Staff Workstations

3. IT Services and Network Infrastructure

Service	Function
Web Server	Host Qubit public website
Authoritative DNS Server	Serve the public zones for swaans.sitict.net.
DHCP Server	Allocate an IP address to different internal clients
AAA Server	VPN and Centralised Device authentication and authorisation (TACACS+)
Development Server (R&D)*	Build/test environment for labs
Cache DNS Server	Improves internal network performance by resolving domain names locally.
NTP Server	Provide accurate, centralised time synchronisation for all servers and network devices to ensure consistent logging and security event correlation.

Jump Host Server	Provide a secure, controlled access point for administrators to manage internal servers and network devices, typically over the OOB management network.
Syslog Service	Centralised logging for network devices and servers to support troubleshooting and security auditing.
Netflow Service	Network traffic flow monitoring to analyse utilisation, detect suspicious patterns, and support incident investigations.

Table 3: IT Services and Network Infrastructure

*Development Server requirements will be made known during the demo

4. IP Addressing and Internet Access

- The 192.168.X.0/24 IP address block is allocated for the internal VLAN network, except for VLAN 100, VLAN 80, Etherchannel and Firewall connected to the edge router..
 - Where the X is dependent on the VLAN ID. (e.g. Vlan 10 have an IP of 192.168.10.0/24)
- The Qubit subscribe to only 1 Internet ISP, due to budget constraints (Public IP address allocated to us: 203.149.210.176/29)
- VLAN 100, connected from core switches and firewalls serving an IP of 192.168.100.0/29
- Port Channel 100, using 192.168.200.0/30
- VLAN 80, connected to the Data Centre from Firewall serving an IP of 192.168.80.0/28
- Firewall connected to the edge router serving an IP address of 192.168.101.0/30

Scope & operating context

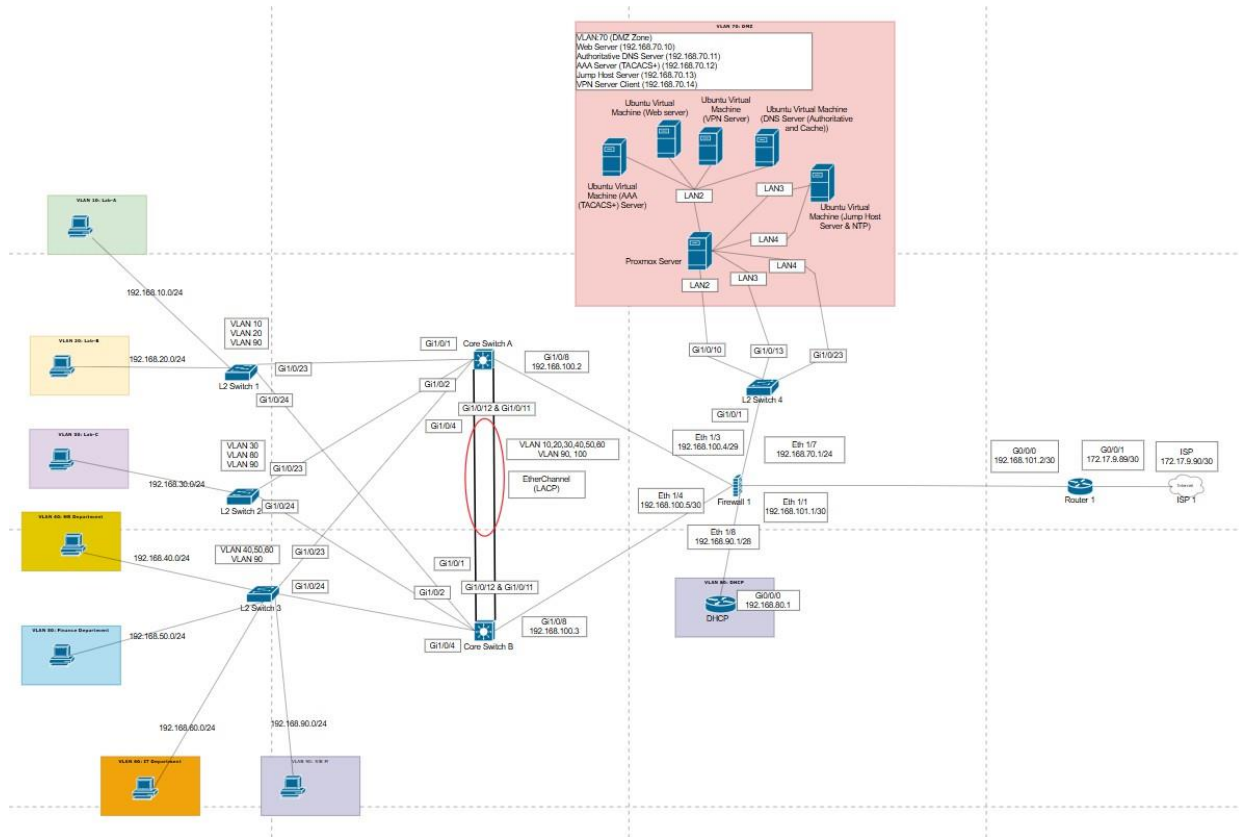
- Three R&D labs (10 endpoints each) may talk within their own lab only.

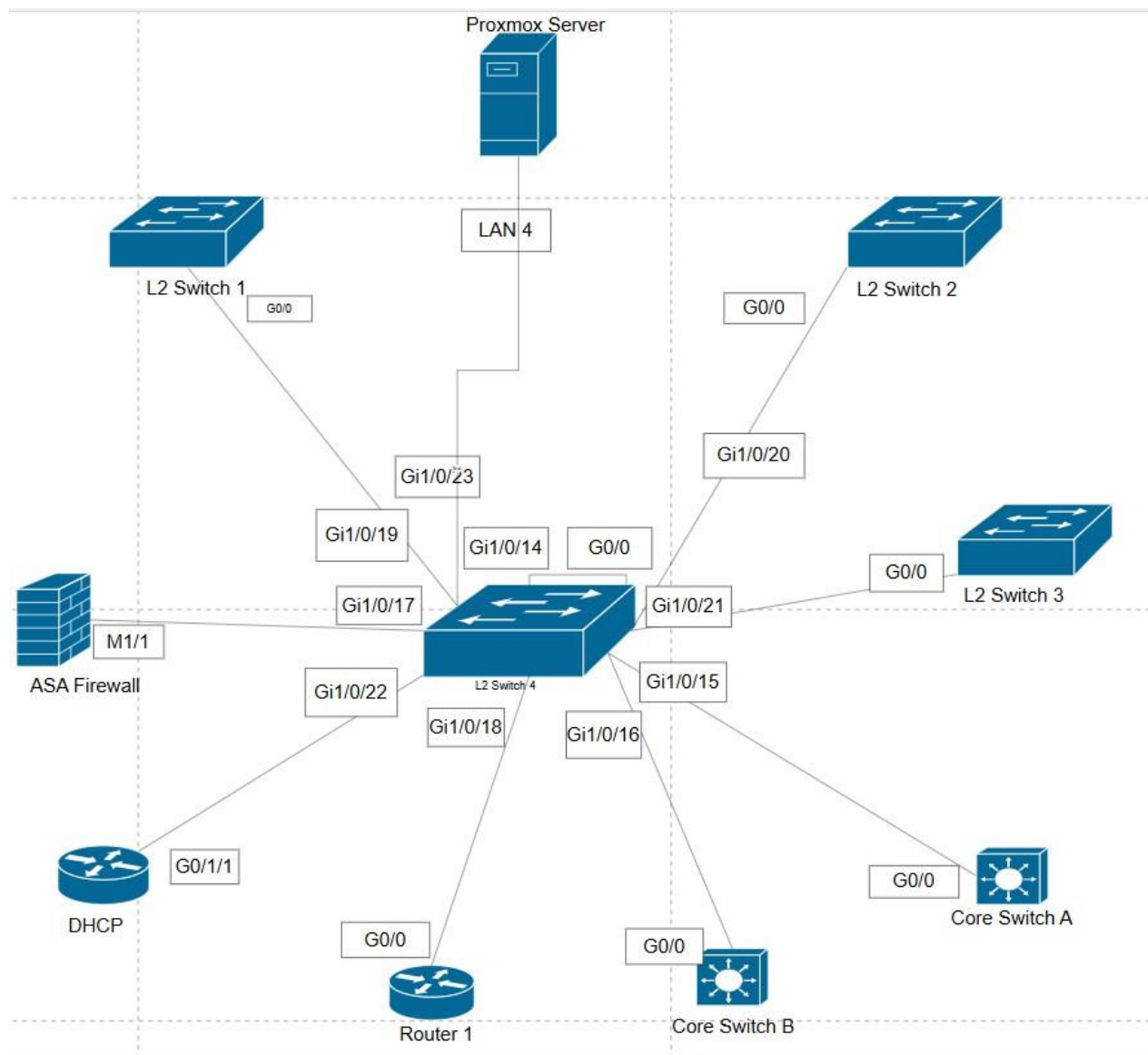
- A development server is reachable only by authorised R&D segments.
- Time-based control: R&D Internet egress is blocked 18:00 - 08:00.
- IT, Finance, HR operate on separate VLANs; Finance↔HR collaboration and Internet access permitted.
- DMZ hosts a public web service and an authoritative DNS server; name resolution via the Closed Internet domain.
- Platform constraints: 1 rack; 2 firewalls, 2 routers, 6 24-port switches.
Currently with a single ISP, but have a design ready for a future second uplink.

Security design stance

- Three-tier core, dist and access with strict VLAN segmentation and least-privilege policy matrices between zones.
- Stateful edge & internal zoning (firewall + ACLs), anti-spoofing, and curated egress filtering.
- NAT for DMZ publication and user egress; object-grouped rules for maintainability.
- AAA for device access and a dedicated OOB management network.
- NSM/telemetry: logging, NTP, and evidence capture for audits and attack-day analysis.
- Implementation of anti-attack configuration commands (i.e. ARP attacks, DHCP attacks and many more) within the core, distribution and access points

Topology





Configuration

Addressing Table without Management

Device	Interface	IP Address	Subnet Mask	HSRP	Connecting Device	
					Device	Interface
L2 Switch 1 (SW1)	Gi1/0/1 - Gi1/0/10	NA	NA	NA	Lab-A	NIC

	Gi1/0/11 - Gi1/0/20	NA	NA	NA	Lab-B	NIC
	Gi1/0/21 - Gi1/0/22	NA	NA	NA	Unused	Unused
	Gi1/0/23	NA	NA	NA	Core Switch A (DSW1)	Gi1/0/1
	Gi1/0/24	NA	NA	NA	Core Switch B (DSW2)	Gi1/0/1
L2 Switch 2 (SW2)	Gi1/0/1 - Gi1/0/10	NA	NA	NA	Lab-C	NIC
	Gi1/0/11 - Gi1/0/20	NA	NA	NA	Spare endpoints	NIC
	Gi1/0/21 - Gi1/0/22	NA	NA	NA	Unused	Unused
	Gi1/0/23	NA	NA	NA	Core Switch A (DSW1)	Gi1/0/2
	Gi1/0/24	NA	NA	NA	Core Switch B (DSW2)	Gi1/0/2
L2 Switch 3 (SW3)	Gi1/0/1 - Gi1/0/3	NA	NA	NA	HR Department (1 Manager, 2 Admin)	NIC
	Gi1/0/4	NA	NA	NA	Unused	Unused
	Gi1/0/5 - Gi1/0/7	NA	NA	NA	Finance Department (1 Manager, 2 Accountants)	NIC
	Gi1/0/8	NA	NA	NA	Unused	Unused
	Gi1/0/9 - Gi1/0/11	NA	NA	NA	IT Department	NIC

					t (1 Network Manager, 2 Network Engineers)	
	Gi1/0/12 - Gi1/0/14	NA	NA	NA	Unused	Unused
	Gi1/0/15	NA	NA	NA	SIEM Host (Syslog & Netflow)	NIC
	Gi1/0/16 - Gi1/0/22	NA	NA	NA	Unused	Unused
	Gi1/0/23	NA	NA	NA	Core Switch A (DSW1)	Gi1/0/4
	Gi1/0/24	NA	NA	NA	Core Switch B (DSW2)	Gi1/0/4
Core Switch A (DSW1)	Gi1/0/1	Trunk	Trunk	NA	L2 Switch 1 (SW1)	Gi1/0/23
	Gi1/0/2	Trunk	Trunk	NA	L2 Switch 2 (SW2)	Gi1/0/23
	Gi1/0/3	NA	NA	NA	Unused	NA
	Gi1/0/4	Trunk	Trunk	NA	L2 Switch 3 (SW3)	Gi1/0/23
	Gi1/0/5 - Gi1/0/7	NA	NA	NA	Unused	NA
	Gi1/0/8	NA	NA	NA	Firewall 1	Eth1/3
	Gi1/0/9 - Gi1/0/10	NA	NA	NA	Unused	NA
	Gi1/0/11 - Gi1/0/12 (LACP)	192.168.200.1	255.255.255.252 (/30)	NA	Core Switch B (DSW2)	Gi1/0/11 - Gi1/0/12
	Gi1/0/13 - Gi1/0/24	NA	NA	NA	Unused	NA
	VLAN 10	192.168.10.1	255.255.	192.168.10	NA	NA

			255.0 (/24)	.2		
	VLAN 20	192.168.20.1	255.255. 255.0 (/24)	192.168.20 .2	NA	NA
	VLAN 30	192.168.30.1	255.255. 255.0 (/24)	192.168.30 .2	NA	NA
	VLAN 40	192.168.40.1	255.255. 255.0 (/24)	192.168.40 .2	NA	NA
	VLAN 50	192.168.50.1	255.255. 255.0 (/24)	192.168.50 .2	NA	NA
	VLAN 60	192.168.60.1	255.255. 255.0 (/24)	192.168.60 .2	NA	NA
	VLAN 90	192.168.90.1	255.255. 255.0 (/24)	192.168.90 .2	NA	NA
	VLAN 100	192.168.100. 2	255.255. 255.248 (/29)	NA	NA	NA
Core Switch B (DSW2)	Gi1/0/1	Trunk	Trunk	NA	L2 Switch 1 (SW1)	Gi1/0/23
	Gi1/0/2	Trunk	Trunk	NA	L2 Switch 2 (SW2)	Gi1/0/23
	Gi1/0/3	NA	NA	NA	Unused	NA
	Gi1/0/4	Trunk	Trunk	NA	L2 Switch 3 (SW3)	Gi1/0/23
	Gi1/0/5 - Gi1/0/7	NA	NA	NA	Unused	NA
	Gi1/0/8	NA	NA	NA	Firewall 1	Eth1/4
	Gi1/0/9 - Gi1/0/10	NA	NA	NA	Unused	NA
	Gi1/0/11 -	192.168.200.	255.255.	NA	Core	Gi1/0/11 -

	Gi1/0/12 (LACP)	2	255.252 (/30)		Switch B (DSW2)	Gi1/0/12
	Gi1/0/13 - Gi1/0/24	NA	NA	NA	Unused	NA
	VLAN 10	192.168.10.1	255.255. 255.0 (/24)	192.168.10 .3	NA	NA
	VLAN 20	192.168.20.1	255.255. 255.0 (/24)	192.168.20 .3	NA	NA
	VLAN 30	192.168.30.1	255.255. 255.0 (/24)	192.168.30 .3	NA	NA
	VLAN 40	192.168.40.1	255.255. 255.0 (/24)	192.168.40 .3	NA	NA
	VLAN 50	192.168.50.1	255.255. 255.0 (/24)	192.168.50 .3	NA	NA
	VLAN 60	192.168.60.1	255.255. 255.0 (/24)	192.168.60 .3	NA	NA
	VLAN 90	192.168.90.1	255.255. 255.0 (/24)	192.168.90 .3	NA	NA
	VLAN 200	192.168.100. 9	255.255. 255.252 (/30)	NA	NA	NA
Firewall 1 (Cisco ASA)	Eth1/1	192.168.101. 1	255.255. 255.252 (/30)	NA	Router 1 (R1)	G0/0/0
	Eth1/2	NA	NA	NA	Unused	NA
	Eth1/3	192.168.100. 4	255.255. 255.248 (/29)	NA	Core Switch A (DSW1)	G1/0/8
	ETH1/4	192.168.100. 10	255.255. 255.252 (/30)	NA	Core Switch B (DSW2)	G1/0/8

	Eth1/5 - Eth1/6	NA	NA	NA	Unused	NA
	Eth1/7	192.168.70.1	255.255.255.0 (/24)	NA	L2 Switch 4 (SW4)	Gi1/0/1
	Eth1/8	192.168.80.1	255.255.255.240 (/28)	NA	DHCP Server (R2)	Gi0/0/0
Router 1 (R1)	G0/0/0	192.168.101.2	255.255.255.252 (/30)	NA	Firewall 1 (Cisco ASA)	Eth1/1
	G0/0/1	172.17.9.89	255.255.255.252 (/30)	NA	Internet (IDO013)	(IDO013)
	G0/1/0	NA	NA	NA	Unused	NA
	G0/1/1	Jump Host Client	-	-	-	-
L2 Switch 4 (SW4)	Gi1/0/1	NA	NA	NA	Firewall 1 (Cisco ASA)	ETH1/7
	G1/0/2 - Gi1/0/9	NA	NA	NA	Unused	NA
	Gi1/0/10	NA	NA	NA	Proxmox Server	LAN 2
	Gi1/0/11 - Gi1/0/12	NA	NA	NA	Unused	NA
	Gi1/0/13	NA	NA	NA	Proxmox Server	LAN 3
	Gi1/0/14	NA	NA	NA	L2 Switch 4 (SW4)	G0/0
	Gi1/0/15	NA	NA	NA	Core Switch A (DSW1)	G0/0
	Gi1/0/16	NA	NA	NA	Core Switch B (DSW2)	G0/0

	Gi1/0/17	NA	NA	NA	Firewall 1 (Cisco ASA)	M1/1
	Gi1/0/18	NA	NA	NA	Router 1 (R1)	G0/1/1
	Gi1/0/19	NA	NA	NA	L2 Switch 1 (SW1)	G0/0
	Gi1/0/20	NA	NA	NA	L2 Switch 2 (SW2)	G0/0
	Gi1/0/21	NA	NA	NA	L2 Switch 3 (SW3)	G0/0
	Gi1/0/22	NA	NA	NA	DHCP Server (R2)	G0/1/1
	Gi1/0/23	NA	NA	NA	Proxmox	LAN 4

Table 4: Addressing Table

Addressing Table for Out-Of-Band (OOB)

Device	Interface	IP address	Subnet Mask	Default Gateway	Connection Device (L2 Switch 4 / SW4)
L2 Switch 1 (SW1)	G0/0	192.168.16.10	255.255.255.0	NA	Gi1/0/19
L2 Switch 2 (SW2)	G0/0	192.168.16.11	255.255.255.0	NA	Gi1/0/20
L2 Switch 3 (SW3)	G0/0	192.168.16.12	255.255.255.0	NA	Gi1/0/21
L2 Switch 4 (SW4)	G0/0	192.168.16.13	255.255.255.0	NA	Gi1/0/14
Core Switch A (DSW1)	G0/0	192.168.16.14	255.255.255.0	NA	Gi1/0/15
Core Switch B (DSW2)	G0/0	192.168.16.15	255.255.255.0	NA	Gi1/0/16

Firewall 1 (Cisco ASA)	M1/1	192.168.16.16	255.255.255.0	NA	Gi1/0/17
Router 1	G0/1/1	192.168.16.17	255.255.255.0	NA	Gi1/0/18
Router 2 (DHCP Server)	G0/1/1	192.168.16.18	255.255.255.0	NA	Gi1/0/22
JumpHost (Proxmox)	LAN 4	192.168.16.100	255.255.255.0	NA	Gi1/0/13

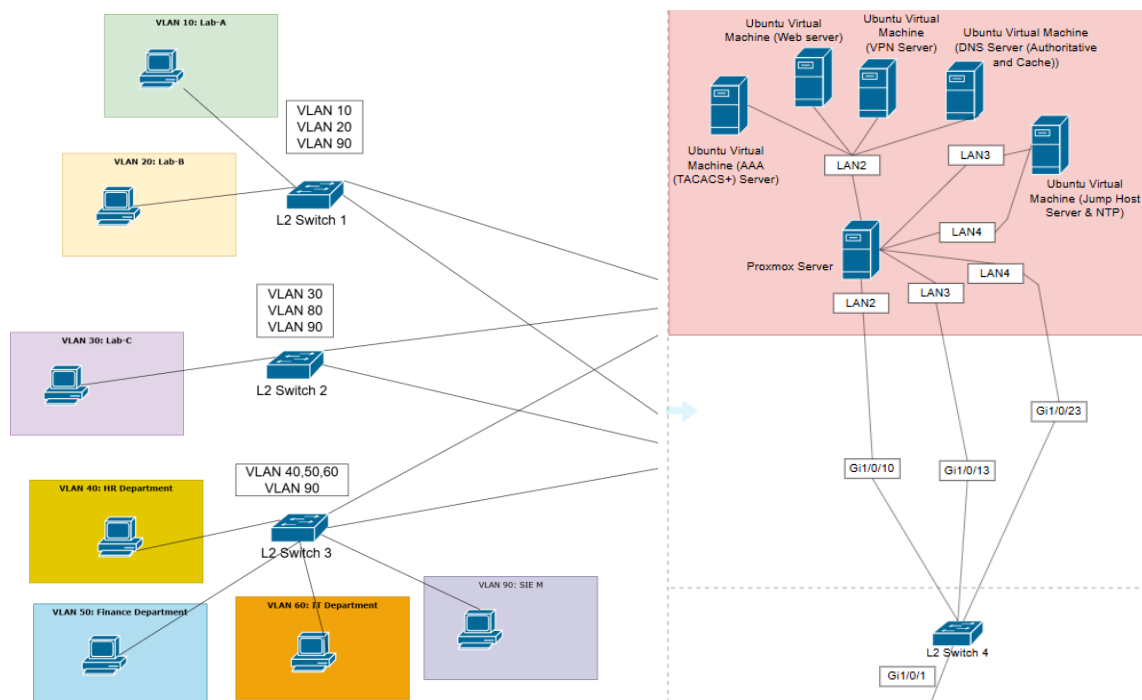
Table 5: OOB Table

Security Design (Defence-In-Depth)

Security is implemented using a defence-in-depth approach, where multiple, independent layers of controls work together to protect the network. At the outer layers, firewalls, ACLs and DMZ segmentation protect against external threats, while internal layers rely on secure routing, authenticated management access, logging (Syslog), and traffic monitoring (NetFlow). This layered strategy reduces the likelihood that a single misconfiguration or compromise will lead to a full network breach.

Layer 2 Switch (Access switches/layer)

1. Introduction



In a network infrastructure, the Layer 2 switch plays a critical role in forwarding traffic within the local area network (LAN). However, this also makes it a prime target for attacks such as MAC flooding, DHCP spoofing, and spanning-tree manipulation. Implementing security at Layer 2 helps protect the network from internal and external threats.

This report analyses the key security mechanisms configured on the switch and explains their functions, operations, and impact.

2. Port Security

Function:

Port security restricts the number and type of MAC addresses that can access a switch port. It helps prevent unauthorised devices from connecting to the network.

Additionally, even though a port is disabled, it's still good practice to apply port security, just in case it gets re-enabled. Port security can help mitigate the risks of unauthorised access if the port is later accidentally enabled.

How It Works:

When enabled with switchport port-security, the switch learns and limits MAC addresses on a per-port basis. If an unknown or excess MAC address tries to connect, the port can take a predefined action (e.g., shut down, restrict, or protect). This helps mitigate MAC address flooding attacks, where attackers overwhelm the switch's MAC table to cause traffic flooding.

Example from Configuration:

```
interface GigabitEthernet1/0/1
description RND A PC
switchport access vlan 10
switchport mode access
switchport nonegotiate
switchport port-security
```

```
interface GigabitEthernet1/0/22
description UNUSED
switchport access vlan 999
switchport mode access
switchport port-security
shutdown
spanning-tree portfast
```

switchport port-security

Configured on all access and unused ports (e.g., GigabitEthernet1/0/1–1/0/22), this ensures only legitimate PCs in VLANs 10 and 20 can access those ports. If an unauthorised device connects, the port can be disabled.

Benefit:

- Protection Against Layer 2 Attacks: Reduces threats from MAC flooding, unauthorised connections, and rogue access points.
- Access Control: Restricts network connectivity to trusted and verified devices only.
- Resource Optimisation: Prevents malicious activities from overloading switch resources.
- Enhanced Network Stability: Minimises the likelihood of broadcast storms caused by compromised or unauthorised devices.

3. DHCP Snooping (with Rate Limiting) and Dynamic ARP Inspection (DAI)

Function:

DHCP snooping protects the network from rogue DHCP servers that can assign incorrect IP addresses to clients and ARP spoofing attacks

How it works:

- DHCP snooping is enabled globally and for VLANs 10 and 20.
- DHCP Option 82 insertion is disabled (no extra info to clients).
- Access ports are untrusted with a rate limit; uplink trunks to CORE use ip dhcp snooping trust.
- Dynamic ARP Inspection is enabled on VLANs 10 and 20, and trunks are configured as ARP inspection trusted.

Example from Configuration:

```
interface GigabitEthernet1/0/1
description RND A PC
switchport access vlan 10
switchport mode access
switchport nonegotiate
switchport port-security
spanning-tree portfast
spanning-tree bpduguard enable
ip dhcp snooping limit rate 10
```

```
ip dhcp pool VLAN20
network 192.168.20.0 255.255.255.0
default-router 192.168.20.1
!
ip dhcp pool VLAN30
network 192.168.30.0 255.255.255.0
default-router 192.168.30.1
!
ip dhcp pool VLAN40
network 192.168.40.0 255.255.255.0
default-router 192.168.40.1
!
```

```
!  
ip dhcp snooping vlan 10,20  
no ip dhcp snooping information option  
ip dhcp snooping  
ip arp inspection vlan 10,20  
login on-success log  
vtp version 1  
!
```

```
interface GigabitEthernet1/0/23  
description UPLINK TO CORE A G1/0/1  
switchport trunk native vlan 999  
switchport trunk allowed vlan 10,20,90  
switchport mode trunk  
switchport nonegotiate  
ip arp inspection trust  
spanning-tree guard loop  
ip dhcp snooping trust  
!
```

Enables DHCP snooping on VLANs 10 and 20. Marks trunk ports (to core switches) as trusted. Limits DHCP traffic rate to 10 packets per second on access ports to prevent DoS attacks.

Benefits:

- Integrity: Prevents rogue DHCP servers and ARP poisoning.
- Availability: Protects users from getting incorrect IP information.
- Foundation for further L2 protections like IP Source Guard (if added).

4. Spanning Tree Protocol (STP) Security

Function:

Spanning Tree Protocol (STP) prevents network loops by controlling which ports forward traffic. Attackers could manipulate STP to become the root bridge, causing traffic redirection or outages.

How It Works:

PortFast: Immediately transitions access ports to forwarding state, improving boot time for end devices. BPDU Guard: Disables the port if a Bridge Protocol Data Unit (BPDU) is received, protecting the STP topology. Loop Guard: Prevents loops in case of unidirectional link failures on trunk ports.

Example from Configuration:

```
interface GigabitEthernet1/0/1
description RND A PC
switchport access vlan 10
switchport mode access
switchport nonegotiate
switchport port-security
spanning-tree portfast
spanning-tree bpduguard enable
ip dhcp snooping limit rate 10
```

spanning-tree portfast (on end devices)

spanning-tree bpduguard enable

spanning-tree guard loop

```
interface GigabitEthernet1/0/1
description TO L2-S1 G1/0/23
switchport trunk native vlan 999
switchport trunk allowed vlan 10,20,90
switchport mode trunk
switchport nonegotiate
spanning-tree guard root
```

spanning-tree guard root

Access ports use PortFast and BPDU Guard, while trunk ports use Loop Guard to maintain topology stability.

Benefit:

- Ensures network stability by preventing Layer 2 loops and maintaining efficient traffic flow.
- Provides resilience through fault-tolerant design with alternate paths in case of primary link failure.

- Protects against STP manipulation and accidental loops caused by misconfigurations or malicious devices.
- Enables automated recovery by restoring ports from inconsistent states once invalid BPDUs are cleared.
- Maintains consistent and reliable network performance under dynamic network conditions.

5. Errdisable Recovery and Violation Handling

Function:

When a security violation (e.g., port security breach) occurs, the switch can automatically disable the affected port. Errdisable recovery allows it to re-enable after a set time.

How It Works:

Detects a port security violation (e.g., unauthorised MAC address). Places the port in an err-disabled state. After 600 seconds (per configuration), it automatically attempts to recover the port.

Example from Configuration:

```
!  
errdisable recovery cause psecure-violation  
errdisable recovery interval 600  
!
```

Benefit:

Minimises downtime after a violation while maintaining strong access control.

6. VLAN Segmentation and Unused Port Shutdown

Function:

Separating devices into VLANs improves traffic management and reduces the broadcast domain size. Shutting down unused ports prevents unauthorised access.

How It Works:

Devices in VLAN 10 and VLAN 20 are isolated. VLAN 999 acts as a “black-hole VLAN” for unused ports. Unused interfaces are administratively shut down to eliminate entry points.

Example from Configuration:

```
interface GigabitEthernet1/0/22
description UNUSED
switchport access vlan 999
switchport mode access
switchport port-security
shutdown
spanning-tree portfast
```

switchport access vlan 999
shutdown

Benefit:

- Prevents unauthorized access by assigning unused switch ports to an inactive VLAN and disabling them, ensuring connected devices cannot reach active network segments.
- Isolates potential threats and prevents unauthorized devices from exploiting open ports.
- Mitigates VLAN hopping attacks by keeping unused VLANs untrunked, which stops malicious users from bypassing VLAN segregation.
- Enhances network security by maintaining clear separation between user groups and sensitive network areas.

7. Secure Remote Access (SSH)

Function:

Secure remote management protocols like SSH, encrypt management traffic to prevent credential theft or eavesdropping.

How It Works:

ip ssh enables SSH access for secure CLI management. The configuration includes PKI trustpoints and certificates for secure authentication.

Example from Configuration:

```
ip ssh time-out 60
ip ssh authentication-retries 5
!
!
logging source-interface Vlan90
logging host 192.168.90.10 transport udp port 520
!
tacacs-server timeout 2
tacacs server 192.168.70.12
  address ipv4 192.168.70.12
  key secret123
!
!
!
control-plane
  service-policy input system-cpp-policy
!
!
line con 0
  login authentication console
  stopbits 1
line vty 0 4
  exec-timeout 30 0
  transport input ssh
line vty 5 15
  transport input ssh
!
```

```
ip ssh time-out 60
ip ssh authentication-retries 5
line vty 0 15
```


login local
transport input ssh

Benefit:

Prevents attackers from intercepting login credentials during remote management sessions.

8. Control Plane Policing (CoPP)

Function:

Control Plane Policing protects the switch CPU from denial-of-service (DoS) attacks or excessive traffic.

How It Works:

Traffic destined for the CPU (e.g., routing updates, STP, ARP requests) is filtered and rate-limited using policies. The class maps (e.g., system-cpp-police-dhcp-snooping, system-cpp-police-l2-control) define which traffic types are controlled.

Example from Configuration:

```
!  
control-plane  
  service-policy input system-cpp-policy  
!
```

Benefit:

Ensures critical processes are not overwhelmed by malicious or excessive traffic, maintaining device stability.

9. User Authentication and Access Control

Function:

User authentication ensures that only authorised administrators can access the switch configuration.

How It Works:

Local username and password databases are used (username Netroot secret,etc...).
SSH is used for encrypted authentication.

Example from Configuration:

```
username Netroot privilege 15 secret 9 $9$qakmZITqxtDNVE$ygFIkNs1IEluXNjH/mWCRQ8XAZxJkczkIxLYKx4T0TQ
```

```
root@pve:~# ssh Netroot@192.168.16.18  
(Netroot@192.168.16.18) Password:
```

username Netroot secret ...
login local

Benefit:

Prevents unauthorised users from making configuration changes.

10. Centralised AAA with TACACS+ and Local Fallback

Function:

Provide centralised authentication, authorisation, and accounting for administrators on the Layer 2 switch.

How it works:

AAA is enabled with aaa new-model. Layer 2 switches sends login and enable requests to a TACACS+ server at 192.168.70.12, with local accounts as fallback. Exec sessions and level-15 commands are logged via AAA accounting.

Example from configuration:

```
!  
aaa authentication login default group tacacs+ local  
aaa authentication login console group tacacs+ local  
aaa authentication enable default group tacacs+ enable  
aaa authorization exec default group tacacs+ local  
aaa accounting exec default start-stop group tacacs+  
aaa accounting commands 15 default start-stop group tacacs+  
!
```

```
!  
tacacs-server timeout 2  
tacacs server 192.168.70.12  
  address ipv4 192.168.70.12  
  key secret123  
!  
!  
!
```

Benefits:

- Centralised control of admin access and privileges.
- Audit trail of login sessions and privileged commands.
- Resilience through local fallback when TACACS+ is unreachable.

11. Role-Based Command Control (Custom Privilege Levels)

Function:

Implement finer-grained control over which commands certain admin roles can use.

How it works:

Specific configuration and show commands are assigned to privilege level 7. This allows creating TACACS+/local users with privilege 7 who can view and perform limited configuration without full level-15 access.

Example from configuration:

```
!  
privilege configure level 7 interface  
privilege exec level 7 configure terminal  
privilege exec level 7 configure  
privilege exec level 7 show ip interface brief  
privilege exec level 7 show ip interface  
privilege exec level 7 show ip  
privilege exec level 7 show running-config  
privilege exec level 7 show  
!
```

Benefits:

- Supports the principle of least privilege.
- Reduces risk of accidental or malicious full configuration changes by junior admins.
- Helps align with segregation-of-duties in larger environments.

12. Login Success Logging and Centralised Syslog

Function:

Log successful logins and forward device logs to a central syslog server.

How it works:

- login on-success log generates syslog messages when logins succeed.
- All logging uses Vlan90 as the source interface and is sent to 192.168.90.10.

Example from configuration:

```
!  
logging source-interface Vlan90  
logging host 192.168.90.10  
!
```

```
login on-success log
```

Benefits:

- Visibility into who is logging into layer 2 switches and from where.
- Centralised logs support monitoring, correlation, and forensics.

13. NTP for Time Synchronisation

Function:

Keep layer 2 switches clock-synchronised for accurate logging and correlation.

How it works:

- NTP server at 192.168.16.100 is used over Mgmt-vrf.
- ntp logging logs significant NTP-related events.

Example from configuration

```
!  
ntp logging  
ntp server vrf Mgmt-vrf 192.168.16.100  
!
```

Benefits

- Accurate timestamps on syslog and AAA events.
- Essential for incident investigation and correlating events across devices.

14. Management Plane Isolation (Mgmt VRF & Management VLAN)

Function:

Separate management traffic from user data traffic to reduce the attack surface.

How it works:

A dedicated Mgmt-vrf and VLAN 90 are used for management IPs and services (TACACS+, Syslog, NTP). Management packets are logically isolated from user VLANs 10 and 20.

Example from configuration:

```
!  
!  
interface GigabitEthernet0/0  
  vrf forwarding Mgmt-vrf  
  ip address 192.168.16.10 255.255.255.0  
!
```

```
!  
interface Vlan90  
  ip address 192.168.90.7 255.255.255.0  
!
```

```
ntp logging  
ntp server vrf Mgmt-vrf 192.168.16.100  
!
```

```
ip tacacs source-interface Vlan90  
ip ssh bulk-mode 131072  
ip ssh time-out 60  
ip ssh authentication-retries 5  
!  
!  
logging source-interface Vlan90  
logging host 192.168.90.10  
!
```

Benefits:

- Limits who can reach management services.
- Protects TACACS+, Syslog, and NTP from user subnet attacks.
- Supports defence in depth by separating control/management from data plane.

15. IP Source Guard (IP Verify Source MAC-Check)

Function:

Stop hosts from spoofing IP or MAC addresses on access ports.

How it works:

On untrusted access ports, the switch only allows traffic whose IP and MAC match the DHCP Snooping bindings. Anything else is dropped.

Example from configuration:

```
interface GigabitEthernet1/0/1
description RND A PC
switchport access vlan 10
switchport mode access
switchport nonegotiate
switchport port-security
spanning-tree portfast
spanning-tree bpduguard enable
ip verify source mac-check
ip dhcp snooping limit rate 10
!
```

Benefits:

- Enforces one IP/MAC binding per port.
- Prevents IP spoofing, MAC spoofing, and address stealing.
- Complements DHCP Snooping and DAI to harden Layer 2.

16. Trunk & Uplink Hardening

Function:

Secure the uplink trunks to the core switches.

How it works:

Trunks use an unused native VLAN (999), only allow required VLANs, disable DTP, and mark uplinks as trusted for DHCP Snooping and DAI.

Example from configuration:

```
interface GigabitEthernet1/0/23
description UPLINK TO CORE A G1/0/1
switchport trunk native vlan 999
switchport trunk allowed vlan 10,20,90
switchport mode trunk
switchport nonegotiate
ip arp inspection trust
spanning-tree guard loop
ip dhcp snooping trust
!
```

Benefits:

- Reduces VLAN hopping attacks via native VLAN misuse.
- Ensures only necessary VLANs traverse the trunk.
- Prevents rogue devices from negotiating a trunk using DTP.

17. Conclusion

Overall, the Layer 2 access switches are configured with a strong set of security controls that work together to protect both the management plane and the user access layer.

Centralised AAA with TACACS+, local encrypted admin accounts, SSH-only remote access, management VRF, and centralised syslog/NTP ensure that administrative access is controlled, monitored, and time-synchronised. This gives clear accountability over who accessed the switch, how, and when, while keeping management traffic logically separated from user networks.

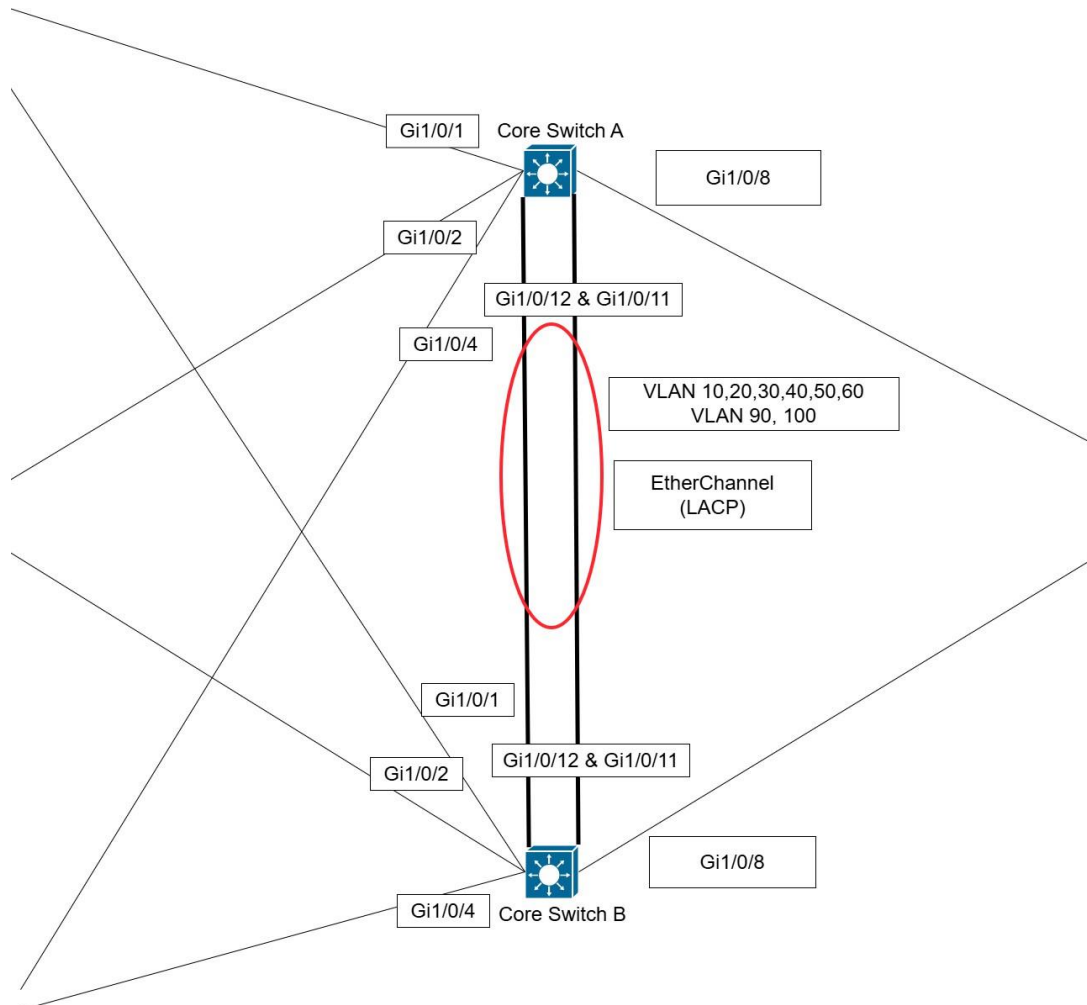
At the same time, the switches enforce robust Layer 2 security at the edge: port security on user ports, DHCP Snooping and Dynamic ARP Inspection on VLANs 10 and 20, BPDU Guard and Portfast on access ports, loop guard and hardened 802.1Q trunks (with an unused native VLAN and restricted allowed VLANs), plus shutdown and sinkholing of unused ports into VLAN 999. These measures significantly reduce the risk of rogue devices, spoofing attacks, VLAN hopping, and accidental loops, thereby preserving the integrity and availability of the campus LAN.

Taken together, the Layer 2 design on S1 supports all three pillars of the CIA triad:

- Confidentiality – by protecting management access and limiting who and what can connect at the edge,
- Integrity – by validating DHCP/ARP behaviour and securing STP and trunks, and
- Availability – by safeguarding the control plane, preventing L2 loops, and ensuring the network remains stable even under error or attack conditions.

Layer 3 Switch (Distribution Switches/Layer)

1. Introduction



In the network infrastructure, the Layer 3 switches form the distribution layer, responsible for inter-VLAN routing, enforcing access control, and acting as a key decision point for traffic between internal segments and the core. Because they control how different departments, R&D labs, and server networks communicate, they are a high-value target for attacks such as unauthorised inter-VLAN access, routing manipulation, or bypassing firewall policies. Implementing strong security at the Layer 3 layer helps ensure that only legitimate, authorised traffic is allowed between VLANs, and that malicious or unexpected traffic can be blocked or closely monitored. This report explains the key Layer 3 security mechanisms configured on the distribution switches and how they support the overall defence-in-depth design.

2. Centralised AAA with TACACS+ and Local Fallback

Function:

Provide centralised authentication, authorisation, and accounting for administrators accessing the core switches.

How it works:

AAA is enabled with `aaa new-model`. The switch sends login and enable requests to a TACACS+ server at 192.168.70.12. If the TACACS+ server is unreachable, the device falls back to the local database. Authorisation controls which users can obtain an EXEC shell, and accounting logs successful sessions and privileged commands.

Example from Configuration:

```
!
aaa new-model
!
!
aaa authentication login default group tacacs+ local
aaa authentication login console group tacacs+ local
aaa authentication enable default group tacacs+ enable
aaa authorization exec default group tacacs+ local
aaa accounting exec default start-stop group tacacs+
aaa accounting commands 15 default start-stop group tacacs+
!
!
```

```
!
tacacs-server timeout 2
tacacs server 192.168.70.12
  address ipv4 192.168.70.12
  key secret123
!
!
```

Benefits:

- Centralised control over admin logins and privilege escalation.
- Resilience via local fallback if TACACS+ is down.
- Audit trail of who logged in, when, and which level-15 commands were executed.
- Supports compliance and forensic investigations.

3. Local Admin Account with Encrypted Secret

Function:

Provide a secure local backup account for administrative access when TACACS+ is not available.

How it works:

A local username is configured with a type-9 encrypted secret. This allows administrators to log in locally if the TACACS+ server cannot be reached, without storing the password in clear text.

Example from configuration:

```
username Netroot privilege 15 secret 9 $9$qakmZITqxtDNVE$ygFIkNs1IEluXNjH/mWCRQ8XAZxJkczkIxLYKx4T0TQ
```

Benefits:

- Ensures availability of management access during TACACS+ outages.
- Improved confidentiality because the password is stored as a hash instead of plain text.
- Supports a controlled break-glass scenario.

4. SSH-Only Remote Management with Session Controls

Function:

Secure remote CLI access to the switch using encrypted SSH sessions, with protection against brute-force and idle sessions.

How it works:

VTY lines accept only SSH (transport input ssh), disabling insecure protocols like Telnet. SSH parameters limit the time allowed for authentication and the number of retries. An EXEC timeout is configured on VTY 0–4 to automatically log out idle sessions.

Example from configuration:

```
stopbits 1
line vty 0 4
  exec-timeout 30 0
  transport input ssh
line vty 5 31
  transport input ssh
!
```

```
ip ssh time-out 60
ip ssh authentication-retries 5
!
```

Benefits:

- Confidentiality of management traffic through encryption.
- Reduced attack surface by disallowing Telnet.
- Limits brute-force attempts via timeouts and retry limits.
- Reduces risk of unattended open sessions via idle timeout.

5. Console Access Protected by AAA

Function:

Protect physical console access using the same AAA policies as remote access.

How it works:

The console line uses an AAA login method list that authenticates against TACACS+ first, with local fallback.

Example from configuration:

```
!
line con 0
  login authentication console
  stopbits 1
```

Benefits:

- Ensures consistent security policy for both local and remote access.
- Prevents unauthorised users from gaining full control via the console.
- Supports centralised logging and auditing of console logins.

6. Management VRF Separation

Function:

Logically separate management traffic from user/data traffic.

How it works:

A dedicated VRF (Mgmt-vrf) is created, and the management interface GigabitEthernet0/0 is placed into this VRF. Management traffic (e.g., NTP, TACACS+ via that interface) is logically isolated from production data paths.

Example from configuration:

```
!  
interface GigabitEthernet0/0  
  vrf forwarding Mgmt-vrf  
  ip address 192.168.16.14 255.255.255.0  
  negotiation auto  
!
```

```
!  
vrf definition Mgmt-vrf  
!  
  address-family ipv4  
  exit-address-family  
!
```

Benefits:

- Segregates management traffic, reducing risk from user subnets.
- Limits the impact of user-plane attacks on management connectivity.
- Aligns with best practice for out-of-band or logically separate management.

7. Login Success Logging

Function:

Log all successful login attempts for audit and monitoring.

How it works:

The login on-success log command instructs the switch to generate a log message every time a login succeeds, which is then sent to the syslog server.

Example from configuration:

```
!  
!  
login on-success log  
vtp version 1  
!  
!
```

Benefits:

- Provides visibility over who is accessing the device and from where.
- Helps detect unexpected or suspicious successful logins.
- Supports compliance and forensic analysis by maintaining an access history.

8. Centralised Syslog

Function:

Send device log messages to a central logging server for monitoring and analysis.

How it works:

The switch uses Vlan90 as the source interface for all syslog messages and sends logs to the central syslog server at 192.168.90.10.

Example from configuration:

```
!  
logging source-interface Vlan90  
logging host 192.168.90.10  
!
```

Benefits:

- Centralises logs for correlation, alerting, and long-term storage.
- Consistent source IP simplifies SIEM integration and log filtering.
- Essential for incident detection and troubleshooting.

9. NetFlow for Traffic Visibility

Function:

Provide detailed visibility into traffic flows for security monitoring and capacity analysis.

How it works:

A flow record (NETFLOW-RECORD) defines which fields are matched and which counters are collected. A flow exporter (NETFLOW-EXPORTER) sends this data to a NetFlow collector at 192.168.90.10 using Vlan90 as the source. A flow monitor (NETFLOW-MONITOR) binds the record and exporter and is applied to key interfaces and VLANs.

Example from configuration:

```
!
!
flow record NETFLOW-RECORD
  match ipv4 source address
  match ipv4 destination address
  match transport source-port
  match transport destination-port
  match ipv4 protocol
  collect counter bytes layer2 long
  collect counter packets long
!
!
flow exporter NETFLOW-EXPORTER
  destination 192.168.90.10
  source Vlan90
  transport udp 9996
!
!
flow monitor NETFLOW-MONITOR
  exporter NETFLOW-EXPORTER
  record NETFLOW-RECORD
!
!
```


Applied to all VLANs such as VLAN 10, 20, 30, 40, 50, 60, 90 and 100. Below is a snippet of a part of the configuration, but the configuration logic is implemented for all VLANs:

```
interface Vlan10
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.10.2 255.255.255.0
ip helper-address 192.168.80.4
standby 10 ip 192.168.10.1
standby 10 priority 120
standby 10 preempt
standby 10 track 100 decrement 30
!
interface Vlan20
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.20.2 255.255.255.0
ip helper-address 192.168.80.4
standby 20 ip 192.168.20.1
standby 20 priority 120
standby 20 preempt
standby 20 track 100 decrement 30
!
interface Vlan30
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.30.2 255.255.255.0
ip helper-address 192.168.80.4
standby 30 ip 192.168.30.1
standby 30 priority 120
standby 30 preempt
standby 30 track 100 decrement 30
```

Benefits:

- Enables detection of anomalous traffic patterns (port scans, exfiltration, unusual flows).
- Supports capacity planning and traffic engineering.
- Provides rich data for threat hunting and incident response.

10. NTP with Event Logging

Function:

Synchronise device time with trusted NTP sources and log NTP events.

How it works:

The switch peers with an NTP server on the inside (192.168.100.1) and an NTP server in the management VRF (192.168.16.100). ntp logging causes NTP-related events (time changes, peer status) to be logged.

Example from configuration:

```
!  
ntp logging  
ntp peer 192.168.100.1  
ntp server vrf Mgmt-vrf 192.168.16.100  
!
```

Benefits:

- Ensures accurate timestamps for syslog and NetFlow, which is critical for forensics.
- Helps correlate events across different devices and systems.
- NTP logs can highlight time sync issues that may affect authentication and logging.

11. Control-Plane Protection (CoPP / CPP)

Function:

Protect the switch control plane from high-rate or malicious traffic that could overload the CPU.

How it works:

Cisco's system control-plane policing is enabled via class-maps and a policy-map (system-cpp-policy). This policy is applied to the control-plane, allowing the device to classify and control traffic destined to the CPU, such as routing updates, ARP, DHCP snooping, multicast control, and exception traffic.

Example from configuration:

```

class-map match-any system-cpp-police-ewlc-control
description EWLC Control
class-map match-any system-cpp-police-topology-control
description Topology control
class-map match-any system-cpp-police-sw-forward
description Sw forwarding, L2 LVX data packets, LOGGING, Transit Traffic
class-map match-any system-cpp-default
description EWLC Data, Inter FED Traffic
class-map match-any system-cpp-police-sys-data
description Openflow, Exception, EGR Exception, NFL Sampled Data, RPF Fail
ed
class-map match-any system-cpp-police-punt-webauth
description Punt Webauth
class-map match-any system-cpp-police-l2lvx-control
description L2 LVX control packets
class-map match-any system-cpp-police-forus
description Forus Address resolution and Forus traffic
class-map match-any system-cpp-police-multicast-end-station
description MCAST END STATION
class-map match-any system-cpp-police-high-rate-app
description High Rate Applications
class-map match-any system-cpp-police-multicast
description MCAST Data
class-map match-any system-cpp-police-l2-control
description L2 control
class-map match-any system-cpp-police-dot1x-auth
description DOT1X Auth
class-map match-any system-cpp-police-data
description ICMP redirect, ICMP_GEN and BROADCAST
class-map match-any system-cpp-police-stackwise-virt-control
description Stackwise Virtual OOB
class-map match-any non-client-nrt-class
class-map match-any system-cpp-police-routing-control
description Routing control and Low Latency
class-map match-any system-cpp-police-protocol-snooping
description Protocol snooping
class-map match-any system-cpp-police-dhcp-snooping

```

```

Data,Transit,DOT1XAuth,Swfwd,LOGGING,L2LVXData,ForusTraffic,ForusARP,McastE
dStn,Openflow,Exception,EGRExcption,NflSampled,RpfFailed
!
policy-map system-cpp-policy
!
!

```

```

!
control-plane
service-policy input system-cpp-policy
!

```

Benefits:

- Protects the CPU from DoS attacks and traffic floods aimed at the control plane.
- Ensures critical functions (routing, management, HSRP, etc.) remain operational under load.
- Improves overall stability and availability of the switch.

12. Layer 2 Trunk Hardening and STP Protection

Function:

Secure VLAN trunks and protect the Layer 2 topology from rogue or misconfigured devices.

How it works:

On trunks to L2 switches, the switch:

- Uses an unused native VLAN (999).
- Restricts allowed VLANs to only those required.
- Disables DTP using switchport nonegotiate.
- Enables Spanning Tree Root Guard to prevent other switches from becoming the root.

Additionally, the global command `vlan dot1q tag native` enforces tagging of the native VLAN, and VLAN 1 has no IP address to avoid use as a management or routed VLAN.

Example from configuration:

```
!  
interface GigabitEthernet1/0/1  
  description T0 L2-S1 G1/0/23  
  switchport trunk native vlan 999  
  switchport trunk allowed vlan 10,20,90  
  switchport mode trunk  
  switchport nonegotiate  
  spanning-tree guard root  
!
```

```
transceiver type all  
  monitoring  
vlan dot1q tag native  
!
```

```
!  
interface Vlan1  
  no ip address  
!  
interface Vlan10
```

The above configuration is applied to Gi1/0/1, Gi1/0/2 and Gi1/0/4 where it is connected to the access layer 2 switches.

Benefits:

- Mitigates VLAN hopping attacks by using an unused native VLAN and tagging it.

- Limits the attack surface by only allowing required VLANs over each trunk.
- Root Guard prevents rogue switches from taking over the STP root role.
- Avoiding IP on VLAN 1 removes a common default management target.

13. OSPF Hardening with Passive Interfaces

Function:

Limit OSPF adjacencies to only trusted transit links, reducing exposure to routing attacks.

How it works:

OSPF process 10 uses passive-interface default, which disables OSPF hello packets on all interfaces. Only the transit interfaces towards the firewall (Vlan100) and Core switches (Port-channel100) are explicitly set as non-passive.

Example from configuration:

```
router ospf 10
router-id 10.10.10.1
passive-interface default
no passive-interface Vlan100
no passive-interface Port-channel100
network 192.168.10.0 0.0.0.255 area 0
network 192.168.20.0 0.0.0.255 area 0
network 192.168.30.0 0.0.0.255 area 0
network 192.168.40.0 0.0.0.255 area 0
network 192.168.50.0 0.0.0.255 area 0
network 192.168.60.0 0.0.0.255 area 0
network 192.168.90.0 0.0.0.255 area 0
network 192.168.100.0 0.0.0.7 area 0
network 192.168.200.0 0.0.0.3 area 0
!
```

Benefits:

- Prevents user VLANs from forming unauthorised OSPF adjacencies.

- Reduces the chance of rogue routers injecting routes.
- Improves overall routing integrity and security.

14. Redundant Gateways Using HSRP

Function:

Provide highly available default gateways for end-user VLANs.

How it works:

Each SVI (Vlan10, 20, 30, 40, 50, 60, 90) runs HSRP with a virtual IP address. Core switches are configured with higher priority (120) and preempt, and the HSRP group tracks track 100 (Port-channel100) so that gateway priority is reduced if the inter-core link fails.

Example from configuration:

```
interface Vlan10
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.10.2 255.255.255.0
 ip helper-address 192.168.80.4
 standby 10 ip 192.168.10.1
 standby 10 priority 120
 standby 10 preempt
 standby 10 track 100 decrement 30
,
```

The configuration is also applied to Vlan 20, 30, 40, 50, 60 and 90.

Benefits

- Enhances availability, providing continuous default-gateway service even during failures.
- Tracking ensures the most appropriate core acts as an active gateway based on path health.
- Though not a “hard security” control, it supports the availability pillar of CIA.

15. Inter-VLAN Access Control for R&D Isolation (ACL RND ISOLATION)

Function:

Enforce network segmentation between R&D VLANs and sensitive departments (HR, Finance, IT) at Layer 3.

How it works:

An extended ACL called RND_ISOLATION is applied inbound on the R&D VLAN interfaces (VLAN 10, 20, 30).

- It permits traffic between the different R&D VLANs.
- It then denies traffic from R&D VLANs to HR (VLAN 40), Finance (VLAN 50), and IT (VLAN 60).
- Finally, a permit ip any any allows other traffic (e.g. to firewall/Internet, shared services) to pass.

Example from configuration:

```
ip access-list extended RND_ISOLATION
10 remark ===== ALLOW R&D VLANs to talk to each other =====
10 permit ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255
20 permit ip 192.168.10.0 0.0.0.255 192.168.30.0 0.0.0.255
30 permit ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
40 permit ip 192.168.20.0 0.0.0.255 192.168.30.0 0.0.0.255
50 permit ip 192.168.30.0 0.0.0.255 192.168.10.0 0.0.0.255
60 permit ip 192.168.30.0 0.0.0.255 192.168.20.0 0.0.0.255
70 remark ===== Block R&D b HR, Finance, IT (and any other internal subnets
if you want) =====
70 deny ip 192.168.10.0 0.0.0.255 192.168.40.0 0.0.0.255
80 deny ip 192.168.10.0 0.0.0.255 192.168.50.0 0.0.0.255
90 deny ip 192.168.10.0 0.0.0.255 192.168.60.0 0.0.0.255
100 deny ip 192.168.20.0 0.0.0.255 192.168.40.0 0.0.0.255
110 deny ip 192.168.20.0 0.0.0.255 192.168.50.0 0.0.0.255
120 deny ip 192.168.20.0 0.0.0.255 192.168.60.0 0.0.0.255
130 deny ip 192.168.30.0 0.0.0.255 192.168.40.0 0.0.0.255
140 deny ip 192.168.30.0 0.0.0.255 192.168.50.0 0.0.0.255
150 deny ip 192.168.30.0 0.0.0.255 192.168.60.0 0.0.0.255
160 remark ===== Allow everything else (e.g. towards ASA for internet, or o
ther allowed traffic) =====
160 permit ip any any
!
```

```
.  
interface Vlan10  
  ip flow monitor NETFLOW-MONITOR input  
  ip flow monitor NETFLOW-MONITOR output  
  ip address 192.168.10.2 255.255.255.0  
  ip helper-address 192.168.80.4  
  ip access-group RND_ISOLATION in  
  standby 10 ip 192.168.10.1  
  standby 10 priority 120  
  standby 10 preempt  
  standby 10 track 100 decrement 30  
.
```

Benefits:

- Enforces **least privilege** between internal departments.
- Protects HR/Finance/IT subnets from direct access by R&D users.
- Limits lateral movement if an R&D machine is compromised.
- Still allows R&D VLANs to reach permitted services (e.g. firewall/Internet, servers).

16. Centralised DHCP via IP Helper (DHCP Relay)

Function:

Provide IP addresses to all VLANs from a central DHCP server, instead of running separate DHCP on every subnet.

How it works:

Each user VLAN SVI uses ip helper-address to relay broadcast DHCP requests to the central DHCP server at 192.168.80.4. The switch converts client broadcasts to unicast and forwards them, so the DHCP server can live in a different network.

Example from configuration:


```
!  
interface Vlan10  
  ip flow monitor NETFLOW-MONITOR input  
  ip flow monitor NETFLOW-MONITOR output  
  ip address 192.168.10.2 255.255.255.0  
  ip helper-address 192.168.80.4  
  ip access-group RND_ISOLATION in  
  standby 10 ip 192.168.10.1  
  standby 10 priority 120  
  standby 10 preempt  
  standby 10 track 100 decrement 30  
!
```

Benefits:

- All IP address management is centralized on one secured DHCP server.
- Easier to enforce DHCP policies and logging in one place.
- Reduces need to run DHCP services on many devices, shrinking attack surface.
- Works nicely with DHCP Snooping on the access switches (which only trust offers coming via the core).

17. High Availability Core Design with SSO & Layer 3 Port-Channel

Function:

Provide high availability and redundancy at the core so a single link or device failure does not bring down the network.

How it works:

- CORE-A is configured with Stateful Switchover (SSO) for redundancy within the switch/stack.
- A Layer 3 Port-Channel (Port-channel100) is formed using two physical links (Gi1/0/11 and Gi1/0/12) towards CORE-B using LACP (channel-group 100 mode active).

- track 100 interface Port-channel100 line-protocol monitors the health of the inter-core link and is used by the gateway redundancy logic (you've already documented HSRP separately).

Example from configuration:

```
!
interface GigabitEthernet1/0/11
  description TO CORE B (Po100 member)
  no switchport
  no ip address
  channel-group 100 mode active
!
interface GigabitEthernet1/0/12
  no switchport
  no ip address
  channel-group 100 mode active
!
```

```
!
interface Port-channel100
  description INTER-CORE L3 TO CORE-B
  no switchport
  ip flow monitor NETFLOW-MONITOR input
  ip flow monitor NETFLOW-MONITOR output
  ip address 192.168.200.1 255.255.255.252
  ip ospf network point-to-point
  ip ospf 10 area 0
!
```

```
!
redundancy
  mode sso
  crypto engine compliance shield disable
!
!
!
!
!
transceiver type all
  monitoring
vlan dot1q tag native
!
track 100 interface Port-channel100 line-protocol
!
```

Benefits:

- Avoids a single point of failure between the two core switches.
- If one physical link fails, traffic continues on the remaining Port-Channel member.

- SSO keeps control-plane state in sync, reducing downtime during failover.
- Together with HSRP (which you already documented), this gives a highly available gateway and core.

18. Conclusion

In summary, the integration of NTP, Syslog, NetFlow, and AAA accounting on core switches creates a strong foundation for time-accurate and event-rich security monitoring. NTP ensures that all logged activities share a consistent and reliable timestamp, while Syslog centralises system events, NetFlow provides detailed visibility into traffic flows, and AAA accounting records administrative actions on the device.

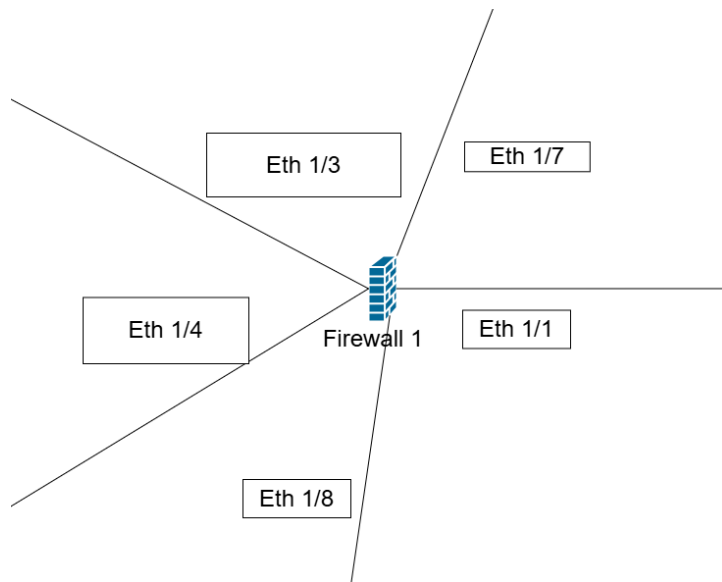
Together, these features enable end-to-end correlation of who did what, when, and what traffic flowed then. This significantly enhances the organisation's ability to perform effective incident response, forensic investigations, and compliance reporting. Most importantly, this combination reinforces all three pillars of the CIA triad:

- Confidentiality, by making suspicious or unauthorised access easier to detect,
- Integrity, by tying configuration changes back to specific users and times, and
- Availability, by allowing issues and attacks to be identified, understood, and resolved more quickly.

Overall, the time and event integrity mechanisms in place on core switches do not act in isolation; they work together as a coherent security monitoring framework that strengthens the resilience and trustworthiness of the entire network.

Firewall

1. Introduction



The ASA firewall (FW1) sits between the campus core and the external network, acting as the main security gateway. It separates users, servers and the Internet into different security zones and enforces stateful inspection, access control, routing, logging and centralised management.

In this design, four routed security zones are defined:

- the **outside** zone (security-level 0), which connects to the ISP router;
- the **dmz** zone (security-level 50), which hosts public-facing services such as the web, DNS, VPN and TACACS+ servers;
- the **dc** zone (security-level 90), which contains internal data centre and infrastructure servers; and

- the **inside** zone (security-level 100), which aggregates internal user networks via the core switch.

In addition, a dedicated **mgmt** interface is used purely for out-of-band management traffic.

Across these zones, the firewall enforces stateful and application-aware inspection using the Modular Policy Framework, performs Layer-3 segmentation between user, server and Internet networks, applies time-based and service-based access control with ACLs, participates in OSPF routing, integrates with centralised AAA (TACACS+) and sends logs to a central Syslog/NetFlow server. Basic threat detection and SYN flood protection are also enabled.

Together, these features form a layered, policy-driven security boundary around Qubit's internal network and critical services.

2. System identity & base settings

Function:

This part of the configuration defines the firewall's identity and basic operating parameters, such as its hostname, domain name, timezone and DNS behaviour. These settings make logs, timestamps and network services consistent across the environment.

How it works:

The commands `hostname FW1` and `domain-name local` set the firewall's name and domain, which then appear in CLI prompts, logs and syslog messages. The line `clock timezone Asia/Singapore` ensures that all timestamps use Singapore time, which is important for correlating events with other devices. DNS resolution is enabled with `dns domain-lookup outside` and `dns server-group DefaultDNS`, allowing the ASA itself to resolve hostnames when features like call-home, certificate validation or external services need it.

Example from configuration:

```
ASA Version 9.20(2)2
hostname FW1
domain-name local
clock timezone Asia/Singapore
dns domain-lookup outside
dns server-group DefaultDNS
domain-name local
```

Benefits

Having a clear hostname and correct timezone makes troubleshooting and auditing much easier, because logs from different systems line up correctly and it is obvious which device generated them. Enabling DNS lookups on the ASA also supports features that rely on names instead of IP addresses, without needing extra manual configuration later.

3. Interface and security zone layout

Function:

The interface configuration creates routed interfaces for each network segment and assigns them to security zones. This is the foundation of the firewall's segmentation between the Internet, user networks, server networks and the management network.

How it works:

Each physical interface is converted to Layer 3 with no switchport where needed, given a nameif, a security-level and an IP address. For example, outside is configured as 192.168.101.1/30 with security-level 0 towards the ISP router, while inside and inside_b are high-trust networks with security-level 100 facing the internal core. The DMZ (dmz, security-level 50) and data centre (dc, security-level 90) host servers on 192.168.70.0/24 and 192.168.80.0/28 respectively. The mgmt interface on 192.168.16.16/24 is marked management-only, which keeps out-of-band administration traffic separate from normal data flows. VLAN1 and VLAN100 are shut and have no nameif, so they do not participate in forwarding.

Example from configuration:

```
interface Ethernet1/1
no switchport
nameif outside
security-level 0
ip address 192.168.101.1 255.255.255.252

interface Ethernet1/3
no switchport
nameif inside
security-level 100
ip address 192.168.100.4 255.255.255.248

interface Ethernet1/4
no switchport
nameif inside_b
security-level 100
ip address 192.168.100.10 255.255.255.252

interface Ethernet1/7
no switchport
power inline auto
nameif dmz
security-level 50
ip address 192.168.70.1 255.255.255.0

interface Ethernet1/8
no switchport
power inline auto
nameif dc
security-level 90
ip address 192.168.80.1 255.255.255.240

interface Management1/1
management-only
nameif mgmt
security-level 100
ip address 192.168.16.16 255.255.255.0
```

Benefits:

This layout gives a clear separation between user LANs, public-facing servers, internal infrastructure servers and management traffic. Security-levels provide an underlying trust hierarchy (inside > dc > dmz > outside), which can then be tightened further with ACLs. Using a dedicated management interface also reduces the risk of exposing admin access on data-plane interface

4. Time-based Internet restrictions for R&D networks

Function:

This section enforces a policy where the R&D lab networks cannot access the Internet outside working hours, while still allowing them to obtain IP addresses and operate normally inside the campus network.

How it works:

- time-range RND_NO_INTERNET defines two blocked windows:
 - 00:00–08:00 daily
 - 18:00–23:59 daily
- ACL INSIDE_OUT applies denies for R&D subnets (192.168.10/20/30.0/24) to “any” using that time range.
- ACL INSIDE_OUT is applied inbound on inside with access-group INSIDE_OUT in interface inside.

Example from configuration:

```
time-range RND_NO_INTERNET
  periodic daily 0:00 to 8:00
  periodic daily 18:00 to 23:59
```

```
access-list INSIDE_OUT extended deny ip 192.168.10.0 255.255.255.0 any time-range RND_NO_INTERNET
access-list INSIDE_OUT extended deny ip 192.168.20.0 255.255.255.0 any time-range RND_NO_INTERNET
access-list INSIDE_OUT extended deny ip 192.168.30.0 255.255.255.0 any time-range RND_NO_INTERNET
```

Benefits:

- Enforces working-hour usage policies automatically.
- No need for manual changes as schedules repeat daily.
- Still allows Internet access for other networks and outside time windows.

5. ICMP restrictions between user LANs and DMZ/DC

Function:

Block ICMP (ping) between user subnets and DMZ/DC subnets while allowing other traffic per policy.

How it works:

- Additional INSIDE_OUT ACEs deny ICMP from several inside ranges (192.168.10/20/30/40/50.0/24) to:
- DMZ: 192.168.70.0/24
- DC: 192.168.80.0/28
- These denials are placed before the general permit ip any any.

Example from configuration:

```
access-list INSIDE_OUT extended permit ip any any
access-list INSIDE_OUT extended deny icmp 192.168.10.0 255.255.255.0 192.168.70.0 255.255.255.0
access-list INSIDE_OUT extended deny icmp 192.168.20.0 255.255.255.0 192.168.70.0 255.255.255.0
access-list INSIDE_OUT extended deny icmp 192.168.30.0 255.255.255.0 192.168.70.0 255.255.255.0
access-list INSIDE_OUT extended deny icmp 192.168.40.0 255.255.255.0 192.168.70.0 255.255.255.0
access-list INSIDE_OUT extended deny icmp 192.168.50.0 255.255.255.0 192.168.70.0 255.255.255.0
access-list INSIDE_OUT extended deny icmp 192.168.10.0 255.255.255.0 192.168.80.0 255.255.255.240
access-list INSIDE_OUT extended deny icmp 192.168.20.0 255.255.255.0 192.168.80.0 255.255.255.240
access-list INSIDE_OUT extended deny icmp 192.168.30.0 255.255.255.0 192.168.80.0 255.255.255.240
access-list INSIDE_OUT extended deny icmp 192.168.40.0 255.255.255.0 192.168.80.0 255.255.255.240
access-list INSIDE_OUT extended deny icmp 192.168.50.0 255.255.255.0 192.168.80.0 255.255.255.240
```

Benefits:

By blocking ICMP while still allowing normal application ports, the design makes server networks less visible to casual scanning from user machines. This reduces the chance that an internal attacker or compromised endpoint can easily map out the DMZ and DC, while still keeping business-critical services reachable.

6. External access to DMZ services

Function:

The OUTSIDE_IN ACL strictly controls what traffic from the Internet is allowed into the DMZ, ensuring that only required public services are reachable and everything else is blocked and logged.

How it works:

- ACL OUTSIDE_IN defines explicit permit entries for:
- DNS (UDP/TCP 53) to 192.168.70.11
- HTTP/HTTPS (80/443) to 192.168.70.10
- UDP/51820 (WireGuard) to 192.168.70.14
- Final explicit deny ip any any log drops and logs all other inbound traffic.
- ACL is applied inbound on outside.

Example from configuration:

```
access-group OUTSIDE_IN in interface outside
```

```
access-list OUTSIDE_IN extended permit udp any host 192.168.70.11 eq domain
access-list OUTSIDE_IN extended permit tcp any host 192.168.70.11 eq domain
access-list OUTSIDE_IN extended permit tcp any host 192.168.70.10 eq www
access-list OUTSIDE_IN extended permit tcp any host 192.168.70.10 eq https
access-list OUTSIDE_IN extended permit udp any host 192.168.70.14 eq 51820
access-list OUTSIDE_IN extended deny ip any any log
```

Benefits:

- Strong “default deny” posture from the Internet to DMZ.
- Only required services are reachable; everything else is blocked and logged for security monitoring.

7. DC internal access control

Function:

Controls what traffic is allowed to leave the Data Centre network (192.168.80.0/28) through the firewall. It only permits specific infrastructure services (DNS, NTP, TACACS+, Syslog) and then **blocks everything else**.

How it works:

- Allows DC servers to query the **Authoritative DNS server** (192.168.70.11) over both UDP and TCP port 53.
- Allows DC servers to sync time with the **NTP server** (192.168.16.100).

- Allows the **DC management server** (192.168.80.4) to talk to the **TACACS+ server** (192.168.70.12) for admin authentication.
- Allows DC devices to send **syslog messages** to the **Syslog/NetFlow server** (192.168.90.10) on UDP port 1520.
- Blocks all other traffic from the DC network and **logs** any attempts, acting as a default “catch-all” rule.

Example from configuration:

```
access-group DC_INTERNAL in interface dc
access-group DMZ_IN in interface dmz
access-list DC_INTERNAL extended permit udp 192.168.80.0 255.255.255.240 host 192.168.70.11 eq domain
access-list DC_INTERNAL extended permit tcp 192.168.80.0 255.255.255.240 host 192.168.70.11 eq domain
access-list DC_INTERNAL extended permit udp 192.168.80.0 255.255.255.240 host 192.168.16.100 eq ntp
access-list DC_INTERNAL extended permit tcp host 192.168.80.4 host 192.168.70.12 eq tacacs
access-list DC_INTERNAL extended permit udp 192.168.80.0 255.255.255.240 host 192.168.90.10 eq 1520
```

Benefits:

- **Least privilege** – DC servers can only reach the exact services they need (DNS, NTP, TACACS+, Syslog), reducing attack surface.
- **Stronger segmentation** – Prevents DC servers from freely talking to other VLANs or the internet through the firewall.
- **Better monitoring** – The deny ip any any log entry records any unusual or unauthorised traffic from the DC, helping with incident detection.
- **Easier troubleshooting** – Clear, service-based rules make it easier to understand and justify why DC traffic is allowed or blocked.

8. Routing and OSPF

Function:

Provide IP reachability between the firewall, internal networks and upstream router using a mix of static routes and OSPF.

How it works:

- Static default routes:
- route outside sends all non-local traffic to 192.168.101.2.
- route mgmt sends management-plane default traffic to 192.168.16.17.

- router ospf 10 advertises inside, DC, DMZ and outside subnets to neighbors and can learn internal routes.
- 'default-information originate' injects a default route into OSPF.

Example from configuration:

```
router ospf 10
  router-id 10.10.10.254
  network 192.168.70.0 255.255.255.0 area 0
  network 192.168.80.0 255.255.255.240 area 0
  network 192.168.100.0 255.255.255.248 area 0
  network 192.168.100.8 255.255.255.252 area 0
  network 192.168.101.0 255.255.255.248 area 0
  log-adj-changes
  default-information originate
!
route outside 0.0.0.0 0.0.0.0 192.168.101.2 1
route mgmt 0.0.0.0 0.0.0.0 192.168.16.17 1
```

Benefits:

- Dynamic route exchange with core/aggregation devices.
- Automatic failover/updates without manual static route changes.
- Default route injection simplifies downstream routing.

9. AAA, TACACS+ and local user

Function:

Centralize admin authentication/authorization on TACACS+ while keeping a local fallback account.

How it works:

- aaa-server TACACS+ defines a TACACS+ server on the DMZ (192.168.70.12) with a shared key.
- SSH and enable logins use AAA (aaa authentication ssh/enable console TACACS+ LOCAL), falling back to local if TACACS+ is unavailable.

- Command and exec authorization use TACACS+.
- Local user shifan with privilege 15 acts as backup or for emergencies.

Example from configuration:

```
aaa-server TACACS+ protocol tacacs+
aaa-server TACACS+ (dmz) host 192.168.70.12
  key *****
user-identity default-domain LOCAL
aaa authentication ssh console TACACS+ LOCAL
aaa authentication enable console TACACS+ LOCAL
aaa authorization command TACACS+ LOCAL
aaa authorization exec authentication-server
no aaa authentication login-history
```

```
username Netroot password ***** pbkdf2 privilege 15
username Netadmin password ***** pbkdf2 privilege 7
```

Benefits:

- Centralized control over who can manage the firewall and what commands they can run.
- Full audit trail on the TACACS+ server.
- Resilient access via local fallback account.

10. Management plane access (SSH, HTTP/ASDM, NTP, DHCP)

Function:

Securely manage the firewall and synchronize time over the dedicated management network.

How it works:

- SSH allowed only from the mgmt subnet (192.168.16.0/24) and a single host 192.168.16.100.
- ASA HTTP/ASDM server enabled for specific subnets on the mgmt interface.

- ntp server 192.168.16.100 source mgmt syncs time via NTP from the management network.
- dhcpd auto_config outside lets the outside interface auto-learn DHCP options (e.g., DNS, domain).

Example from configuration:

```
no ssh stack ciscossh
ssh stricthostkeycheck
ssh timeout 60
ssh version 2
ssh key-exchange group dh-group14-sha256
ssh 192.168.16.100 255.255.255.255 mgmt
ssh 192.168.16.0 255.255.255.0 mgmt
console timeout 10
dhcpd auto_config outside
!
threat-detection basic-threat
threat-detection statistics access-list
no threat-detection statistics tcp-intercept
ntp server 192.168.16.100 source mgmt
```

Benefits:

- Management reachable only from explicit admin networks.
- Encrypted access using SSH and HTTPS/ASDM.
- Accurate time for logging, AAA and time-based ACLs.

11. Logging and threat detection

Function:

Record firewall events and detect basic anomalous traffic patterns.

How it works:

- logging enable, logging trap informational and logging asdm informational configure syslog/ASDM logging level.
- threat-detection basic-threat and threat-detection statistics access-list gather statistics on flows and ACL hits.

Example from configuration:

```
logging enable
logging trap informational
logging asdm informational
```

```
threat-detection basic-threat
threat-detection statistics access-list
no threat-detection statistics tcp-intercept
```

Benefits:

- Visibility into allowed/denied traffic and security events.
- Helps troubleshoot issues and identify attacks or misconfigurations.

12. Application inspection & global policy

Function:

Provide stateful inspection and protocol fix-ups for common applications.

How it works:

- class-map inspection_default matches the default inspection traffic.
- policy-map global_policy applies a set of inspect actions for protocols like FTP, SIP, DNS-related apps, etc.
- The policy map is applied globally via service-policy global_policy global.

Example from configuration:

```
policy-map OUTSIDE_SYN_POLICY
  class SYN_FLOOD_PROTECT
    set connection conn-max 2000 embryonic-conn-max 200 per-client-max 50 per-client-embryonic-max 20
    set connection timeout idle 0:01:00
policy-map global_policy
  class inspection_default
    inspect ftp
    inspect h323 h225
    inspect h323 ras
    inspect ip-options
    inspect netbios
    inspect rsh
    inspect rtsp
    inspect skinny
    inspect esmtp
    inspect sqlnet
    inspect sunrpc
    inspect tftp
    inspect sip
    inspect icmp
  class class-default
```

Benefits:

- Correct handling of protocols that open dynamic ports or embed IP/port info in payloads.
- Improves security by enforcing protocol compliance.
- Better visibility into application-layer traffic.

13. Connection/translation timers

Function:

Control how long various sessions and translations stay in the firewall's state tables.

How it works:

- timeout commands set lifetimes for connections, NAT translations, and inspections (TCP, UDP, SIP, etc.).
- Shorter timers free resources faster; longer timers favor long-lived sessions.

Example from configuration:

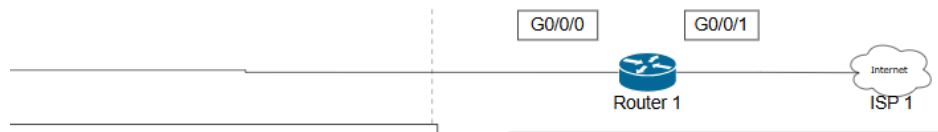
```
timeout xlate 3:00:00
timeout pat-xlate 0:00:30
timeout conn 1:00:00 half-closed 0:10:00 udp 0:02:00 sctp 0:02:00 icmp 0:00:02
timeout sunrpc 0:10:00 h323 0:05:00 h225 1:00:00 mgcp 0:05:00 mgcp-pat 0:05:00
timeout sip 0:30:00 sip_media 0:02:00 sip-invite 0:03:00 sip-disconnect 0:02:00
timeout sip-provisional-media 0:02:00 uauth 0:05:00 absolute
timeout tcp-proxy-reassembly 0:01:00
timeout floating-conn 0:00:00
timeout conn-holddown 0:00:15
timeout igp stale-route 0:01:10
```

Benefits:

- Prevents stale sessions from consuming memory indefinitely.
- Lets you tune behavior for your environment (e.g., chatty vs. bursty traffic).

Router (Edge Layer)

1. Introduction



R1 sits between your ASA (inside/DMZ side) and the ISP. It provides public IP publishing (static NAT), outbound PAT, default routing to the ISP, and management access. The edge router R1 is hardened as a security gateway between the internal network and the ISP, not just a basic routing box. At the WAN edge, it uses an inbound ACL to block SSH to the public DMZ servers, while static NAT only publishes selected DMZ hosts and PAT with a public pool hides internal IPs for outbound Internet access. NetFlow on the inside, outside, and management links exports detailed traffic records for monitoring, and all unused interfaces are shut down, reducing the physical attack surface.

For administration, R1 enforces SSH-only access with AAA (TACACS+) and local fallback, and places the management interface inside a dedicated Mgmt-VRF so management traffic is isolated from user data. Syslog and NTP send time-synchronised logs to a central server. Together, these controls make R1 a properly secured Internet edge device that controls exposure, protects admin access, and supports effective security monitoring.

2. Edge Roles, Interfaces & Unused Port Hardening

Function:

Define clear inside/outside/management roles on the router and reduce attack surface by disabling unused interfaces.

How it works:

- Gi0/0/0 is the inside/NAT-inside transit toward the ASA outside.
- Gi0/0/1 is the outside/NAT-outside WAN toward the ISP.
- Gi0/1/1 sits in Mgmt-vrf and is used for out-of-band management, separate from data-plane traffic.

- Unused physical interfaces (Gi0/0/2, Gi0/0/3, Gi0/1/0) are set to shutdown with no IP address, so nobody can just plug in and get access.

Example from configuration:

```
interface GigabitEthernet0/0/0
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.101.2 255.255.255.252
 ip nat inside
 negotiation auto
!
interface GigabitEthernet0/0/1
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 172.17.9.89 255.255.255.252
 ip nat outside
 ip access-group INTERNET-IN in
 negotiation auto
!
interface GigabitEthernet0/0/2
 no ip address
 shutdown
 negotiation auto
!
interface GigabitEthernet0/0/3
 no ip address
 shutdown
 negotiation auto
!
```

```
interface GigabitEthernet0/1/0
 no ip address
 shutdown
 negotiation auto
!
interface GigabitEthernet0/1/1
 vrf forwarding Mgmt-vrf
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.16.17 255.255.255.0
 negotiation auto
!
```

Benefits:

- Clear separation of inside, outside, and management planes.
- Reduces the chance of misconfigurations (e.g. mixing up NAT roles).
- Disabled unused ports remove easy plug-in attack points.
- Works together with NAT, ACL and NetFlow to make the router a clean, well-defined Internet edge.

3. Secure Public Exposure via Static NAT and PAT

Function:

Control which internal servers are reachable from the Internet, while hiding internal IP addresses for general outbound traffic.

How it works:

- Static NAT publishes selected DMZ hosts (192.168.70.10, .11, .14) to fixed public IPs 203.149.210.177–179. Only these hosts are exposed on those public IPs.
- PAT (overload) uses the MY_POOL to translate all other “inside” sources (matching ACL 1) to a small range of public IPs for outbound Internet.
- DNS NAT is explicitly disabled (no ip nat service dns ...) to avoid DNS doctoring behaviour.

Example from configuration:

```
.
no ip nat service dns tcp
no ip nat service dns udp
ip nat pool MY_POOL 203.149.210.180 203.149.210.182 netmask 255.255.255.248
ip nat inside source static 192.168.70.10 203.149.210.177
ip nat inside source static 192.168.70.11 203.149.210.178
ip nat inside source static 192.168.70.14 203.149.210.179
ip nat inside source list 1 pool MY_POOL overload
.
```

```
interface GigabitEthernet0/0/0
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.101.2 255.255.255.252
 ip nat inside
 negotiation auto
!
interface GigabitEthernet0/0/1
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 172.17.9.89 255.255.255.252
 ip nat outside
 ip access-group INTERNET-IN in
 negotiation auto
```

Benefits:

- Only specific DMZ servers are reachable from the Internet on known public IPs.
- All other internal clients share a few public IPs for outbound access, hiding internal addressing.
- Disabling ip nat service dns avoids weird DNS rewriting that can be confusing or abused.
- Clear separation of published services vs general outbound users.

3. Internet Edge ACL to Block SSH to Public Servers

Function:

Prevent direct SSH access from the Internet to the public-facing servers in the DMZ.

How it works:

- An extended ACL INTERNET-IN is applied inbound on the outside interface Gi0/0/1.

- It denies SSH (TCP/22) from any Internet host to the three public IPs used by DMZ servers, then permits all other IP traffic.
- It denies ping requests from any internet host to the dedicated public IPs and, in addition, prevents internal IPs from being pinged.
- This adds a Layer 3 filter on top of the NAT rules, specifically hardening the management surface of public servers.

Example from configuration:

```
ip access-list extended INTERNET-IN
10 deny tcp any host 203.149.210.177 eq 22
20 deny tcp any host 203.149.210.178 eq 22
30 deny tcp any host 203.149.210.179 eq 22
40 deny icmp any 203.149.210.176 0.0.0.7 echo
50 deny icmp any 192.168.0.0 0.0.255.255
60 permit ip any any
!
```

```
interface GigabitEthernet0/0/1
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 172.17.9.89 255.255.255.252
ip nat outside
ip access-group INTERNET-IN in
negotiation auto
!
```

Benefits:

- Blocks Internet attackers from SSH-ing directly into DMZ servers.
- Still allows intended services (HTTP/HTTPS/DNS/VPN, etc.) on those IPs.
- Simple but effective first line of defence at the Internet edge, tightly aligned with your NAT design.

4. Routing & Forwarding Hygiene

Function:

Ensure clean, predictable forwarding between ISP and campus/DMZ, and provide an option to drop spoofed traffic at the edge.

How it works:

- Default route sends all Internet-bound traffic to the ISP (172.17.9.90) via Gi0/0/1.
- Return traffic towards campus/DMZ (192.168.0.0/16) is sent to the ASA outside IP (192.168.101.1), which then knows how to reach internal VLANs and DMZ.

Example from configuration:

```
ip route 0.0.0.0 0.0.0.0 172.17.9.90
ip route 192.168.0.0 255.255.0.0 192.168.101.1
```

Benefits:

- Clean, deterministic forwarding path in both directions (Internet ↔ ISP ↔ R1 ↔ ASA ↔ internal).
- Avoids routing loops or blackholes for DMZ/campus networks.
- Sets a solid foundation for scaling to dynamic routing (e.g. BGP) later if needed.

5. Traffic Visibility with NetFlow on Inside, Outside, and Management Links

Function:

Provide detailed traffic visibility for security monitoring and anomaly detection across all key paths (inside, outside, and management).

How it works:

- A NetFlow record, exporter, and monitor are defined.

- The same monitor is applied on:
 - Inside interface Gi0/0/0
 - Outside interface Gi0/0/1
 - Management interface Gi0/1/1
- Flow data is exported to the collector at 192.168.90.10 on UDP port 9996.

Example from configuration:

```
!
flow record NETFLOW-RECORD
 match ipv4 source address
 match ipv4 destination address
 match transport source-port
 match transport destination-port
 match ipv4 protocol
 collect counter bytes layer2 long
 collect counter packets long
!
!
flow exporter NETFLOW-EXPORTER
 destination 192.168.90.10
 source GigabitEthernet0/0/0
 transport udp 9996
!
!
flow monitor NETFLOW-MONITOR
 exporter NETFLOW-EXPORTER
 record NETFLOW-RECORD
!
```

```
!
interface GigabitEthernet0/0/0
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.101.2 255.255.255.252
 ip nat inside
 negotiation auto
!
interface GigabitEthernet0/0/1
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 172.17.9.89 255.255.255.252
 ip nat outside
 ip access-group INTERNET-IN in
 negotiation auto
!
```

```
!
interface GigabitEthernet0/1/1
 vrf forwarding Mgmt-vrf
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.16.17 255.255.255.0
 negotiation auto
!
```

Benefits:

- Lets admins/SOC see who is talking to whom across inside, outside, and management.
- Supports detection of DoS attacks, port scanning, or unusual spikes towards DMZ/public IPs.
- Provides rich data for forensic investigations after an incident.
- Complements your ACL/NAT/AAA design by giving visibility, not just control.

6. SSH & AAA-Based Administrative Access

Function:

Secure router administration using SSH-only remote access combined with centralized AAA (TACACS+) and local fallback.

How it works:

- `aaa new-model` enables AAA on the router.
- Login and enable authentication are sent first to the TACACS+ server at 192.168.70.12; if TACACS+ is down, the router falls back to local users (Netadmin, Netroot).
- VTY lines accept only SSH (transport input ssh), with an exec-timeout and SSH time-out / retry limits to reduce brute-force attempts.
- Console (line con 0) is also tied to AAA, so even physical access still requires proper credentials.

Example from configuration:

```
aaa new-model
!
!
aaa authentication login default group tacacs+ local
aaa authentication login console group tacacs+ local
aaa authentication enable default group tacacs+ enable
aaa authorization exec default group tacacs+ local
aaa accounting exec default start-stop group tacacs+
aaa accounting commands 15 default start-stop group tacacs+
```

```
tacacs server 192.168.70.12
address ipv4 192.168.70.12
key secret123
```

```
ip ssh time-out 60
ip ssh authentication-retries 5
```

```
!
line con 0
login authentication console
stopbits 1
line aux 0
line vty 0 4
exec-timeout 30 0
transport input ssh
line vty 5 14
transport input ssh
```

```
username shifan secret 9 $9$ijq6wW2uiwMJg.$D5zWuK2Z1rJBoHGEiLuX54yMGXprbh6Kh
urHfcloGJ2
username admin secret 9 $9$8K58u6vy31tUNE$yXs75kYGFoxVDZTeFdhXEixvPasiJ/pVdr
R64g8wKDs
```

Benefits:

- Only authenticated admins can access the router, via TACACS+ or local fallback.
- SSH-only remote access means no Telnet/clear-text passwords on the wire.

- Accounting on exec/commands (level 15) gives an audit trail of who did what.
- Console is also protected by AAA, so physical access alone is not enough.

7. Management VRF with Centralised Logging & Time Synchronisation

Function:

Isolate management-plane traffic from user data, and ensure all admin and security events are centrally logged with accurate timestamps.

How it works:

- Mgmt-vrf is defined and bound to interface Gi0/1/1 (vrf forwarding Mgmt-vrf), creating a separate routing table just for management traffic.
- Management protocols (SSH/HTTPS/TACACS+/NTP, NetFlow source, etc.) use this VRF, keeping them logically separated from data-plane routes.
- logging host 192.168.90.10 sends syslog messages (including login on-success log) to a central log server.
- ntp server vrf Mgmt-vrf 192.168.16.100 with ntp logging ensures the router's clock is accurate, so all logs have correct timestamps.

Example from configuration:

```
interface GigabitEthernet0/1/1
 vrf forwarding Mgmt-vrf
 ip flow monitor NETFLOW-MONITOR input
 ip flow monitor NETFLOW-MONITOR output
 ip address 192.168.16.17 255.255.255.0
 negotiation auto
```

```
login on-success log
```

```
!  
vrf definition Mgmt-vrf  
!  
address-family ipv4  
exit-address-family  
!
```

```
logging host 192.168.90.10
```

```
ntp logging  
ntp server vrf Mgmt-vrf 192.168.16.100
```

Benefits:

- Management traffic is logically isolated, reducing the chance that user/data paths can reach the management IP.
- Central syslog collection gives a single place to review security events, config changes, and login activity.
- NTP + logging = accurate, time-aligned logs across devices, which is crucial for incident investigation and compliance.
- Combined with NetFlow and ACLs, gives you both control and visibility over what happens at the Internet edge and on the router itself.

8. Suppressing ICMP Unreachables on the Internet-Facing Interface

Function:

Reduce information leakage to the Internet by not sending ICMP “destination unreachable” messages when traffic is blocked or not routable on the WAN interface.

How it works:

By default, when the router drops a packet (e.g. due to ACL, no route, or closed port), it may send an ICMP unreachable message back to the source. This behaviour can help legitimate troubleshooting, but it also gives attackers feedback about which IPs/ports/routes are valid.

The command `no ip unreachable` under the outside interface stops the router from generating these ICMP error messages. From an attacker’s point of view, many probes will simply “disappear” with no reply, making it harder to:

- Map which addresses/ports are being filtered vs which ones exist.

- Infer ACL or NAT behaviour based on different ICMP responses.

Example from configuration:

```
!  
interface GigabitEthernet0/0/1  
 ip flow monitor NETFLOW-MONITOR input  
 ip flow monitor NETFLOW-MONITOR output  
 ip address 172.17.9.89 255.255.255.252  
 no ip unreachable  
 ip nat outside  
 ip access-group INTERNET-IN in  
 negotiation auto  
!
```

Benefits:

- Reduces information disclosure to external scanners (fewer hints about your ACLs, valid hosts, or routing).
- Makes the router's outside interface appear more "silent" and harder to fingerprint.
- Can slightly reduce CPU load from generating ICMP error traffic during scans or attacks.

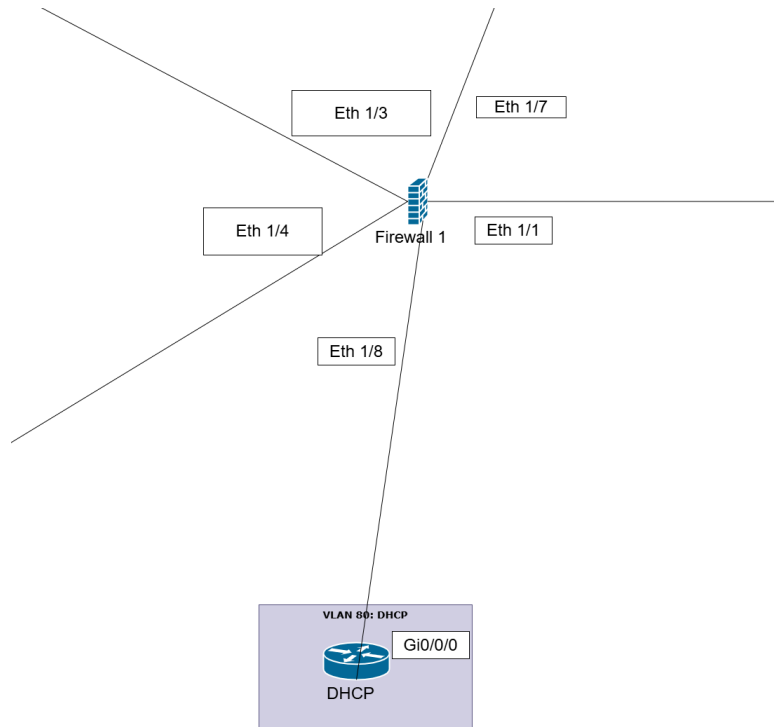
9. Conclusion

In summary, the Internet edge router R1 has been configured as a secure gateway rather than a simple transit device. It tightly controls exposure of internal services using a combination of edge ACLs, static NAT for specific DMZ servers, and PAT for general outbound users, while hardening the platform with shutdown unused interfaces and clean routing towards the ASA and ISP.

On the management side, SSH with AAA (TACACS+), Mgmt-VRF, central syslog, NTP, collectively protect administrative access and ensure that all activities are logged and traceable. Together, these measures provide a layered defence at the router itself, supporting the overall defence-in-depth design of the Qubit network.

DHCP Server

1. Introduction



The DHCP-Server is the central point for issuing IP addresses to all user VLANs, so it's treated as more than just an "IP distributor". It is carefully configured to protect critical infrastructure addresses using excluded ranges, and each DHCP pool hands out trusted default gateways and a single internal DNS server (192.168.70.11). This reduces the risk of IP conflicts and helps prevent clients from being redirected to rogue gateways or DNS servers.

On the platform side, the server is hardened with management separation via Mgmt-vrf, SSH-only remote access with local authentication, and shutdown unused interfaces to reduce the attack surface. Security monitoring is strengthened through centralized syslog and NTP plus NetFlow on both the service and management interfaces, giving visibility into who is talking to the DHCP server and when. Together, these controls ensure the DHCP-Server

supports the network securely while fitting into the wider defence-in-depth design.

2. DHCP Scope Protection with Excluded Addresses

Function:

Protect infrastructure IPs (gateways, servers, static devices) from being accidentally leased to clients.

How it works:

ip dhcp excluded-address reserves specific address ranges in each subnet so the DHCP server never hands them out. This prevents IP conflicts with default gateways, core devices, or statically configured hosts.

Example from configuration:

```
!  
ip dhcp excluded-address 192.168.80.1 192.168.80.4  
ip dhcp excluded-address 192.168.10.1 192.168.10.99  
ip dhcp excluded-address 192.168.10.200 192.168.10.254  
ip dhcp excluded-address 192.168.20.1 192.168.20.99  
ip dhcp excluded-address 192.168.20.200 192.168.20.254  
ip dhcp excluded-address 192.168.30.1 192.168.30.99  
ip dhcp excluded-address 192.168.30.200 192.168.30.254  
ip dhcp excluded-address 192.168.40.1 192.168.40.99  
ip dhcp excluded-address 192.168.40.200 192.168.40.254  
ip dhcp excluded-address 192.168.50.1 192.168.50.99  
ip dhcp excluded-address 192.168.50.200 192.168.50.254  
ip dhcp excluded-address 192.168.60.1 192.168.60.99  
ip dhcp excluded-address 192.168.60.200 192.168.60.254  
ip dhcp excluded-address 192.168.90.1 192.168.90.99  
ip dhcp excluded-address 192.168.90.200 192.168.90.254  
!
```

Benefits:

- Prevents IP conflicts with default gateways, servers, and infra devices.
- Ensures only the intended dynamic range (e.g. .100–.199) is used for clients.
- Works hand-in-hand with DHCP snooping on switches so only this authorised DHCP server can issue leases.

2. Authoritative DHCP Pools with Trusted Internal DNS

Function:

Ensure clients receive the correct gateway and DNS server, reducing risk of traffic hijack by rogue DHCP.

How it works:

Each VLAN has its own DHCP pool with a fixed default router and a single DNS server (192.168.70.11 – your internal DNS). Because this is the authorised server, hosts consistently use the right gateway and DNS instead of random/rogue values.

Example from configuration:

```
!
ip dhcp pool VLAN20
 network 192.168.20.0 255.255.255.0
 default-router 192.168.20.1
 dns-server 192.168.70.11
!
ip dhcp pool VLAN30
 network 192.168.30.0 255.255.255.0
 default-router 192.168.30.1
 dns-server 192.168.70.11
!
ip dhcp pool VLAN40
 network 192.168.40.0 255.255.255.0
 default-router 192.168.40.1
 dns-server 192.168.70.11
!
ip dhcp pool VLAN50
 network 192.168.50.0 255.255.255.0
 default-router 192.168.50.1
 dns-server 192.168.70.11
!
```

```
!
ip dhcp pool VLAN60
 network 192.168.60.0 255.255.255.0
 default-router 192.168.60.1
 dns-server 192.168.70.11
!
ip dhcp pool VLAN90
 network 192.168.90.0 255.255.255.0
 default-router 192.168.90.1
 dns-server 192.168.70.11
!
ip dhcp pool VLAN10
 network 192.168.10.0 255.255.255.0
 default-router 192.168.10.1
 dns-server 192.168.70.11
!
```

Benefits:

- Clients always receive trusted gateway and DNS details from a single, official source.
- Reduces the chance that a rogue DHCP server can silently redirect traffic to malicious gateways/DNS.
- Supports consistent security policies (e.g. DNS filtering, logging) via that internal DNS.

3. Interface Roles, Management VRF & Unused Port Hardening

Function:

Separate management traffic from data, and reduce attack surface by disabling unused interfaces.

How it works:

- Gi0/0/0 is the service interface facing the internal network (192.168.80.4/28) used for DHCP relay from cores.
- Gi0/1/1 is placed in Mgmt-vrf as a dedicated management interface (192.168.16.18/24).
- All other interfaces are shutdown with no IP so no one can plug in and create a backdoor into the DHCP server.

Example from configuration:

```
!
interface GigabitEthernet0/0/1
no ip address
shutdown
negotiation auto
!
interface GigabitEthernet0/0/2
no ip address
shutdown
negotiation auto
!
interface GigabitEthernet0/0/3
no ip address
shutdown
negotiation auto
!
interface GigabitEthernet0/1/0
no ip address
shutdown
negotiation auto
!
interface GigabitEthernet0/1/1
vrf forwarding Mgmt-vrf
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.16.18 255.255.255.0
negotiation auto
!
```

```
.
vrf definition Mgmt-vrf
!
address-family ipv4
exit-address-family
.
```

```
interface GigabitEthernet0/0/0
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.80.4 255.255.255.240
negotiation auto
!
```

Benefits:

- Management traffic is logically separated from DHCP/data traffic.
- Shutting unused ports removes easy physical entry points for attackers.
- Makes the DHCP server more predictable and easier to secure because only expected interfaces are active.

4. Secure Remote Management (SSH, Local Auth)

Function:

Protect administrative access to the DHCP server with encrypted protocols and authenticated logins.

How it works:

- VTY lines use local login plus transport input ssh so only SSH is allowed, no Telnet.
- SSH time-out and retry limits reduce brute-force attempts.

Example from configuration:

```
line vty 0 4
 login local
 transport input ssh
line vty 5 15
 login local
 transport input ssh
!
```

```
ip ssh time-out 60
ip ssh authentication-retries 5
!
```

```
username shifan secret 9 $9$CmVh0SMM/xMziU$qAy7zwB/b0AEtShJJJeU2r6/7RIcTgwC0v
Xj1X2tVuw2
!
```

Benefits:

- Admin logins are encrypted (SSH) instead of clear-text.
- Only authenticated users with local credentials can manage the device.

5. Centralised Logging and Time Synchronisation

Function:

Ensure management and security events are logged centrally with accurate timestamps.

How it works:

- logging host 192.168.90.10 sends syslog output to a central log server.
- login on-success log records successful login attempts, which then get forwarded to syslog.
- ntp server vrf Mgmt-vrf 192.168.16.100 plus ntp logging keep the clock in sync and log NTP events.

Example from configuration:

```
ntp logging
ntp server vrf Mgmt-vrf 192.168.16.100
!
```

```
!
logging host 192.168.90.10
!
```

```
!
login on-success log
!
```

Benefits:

- Centralised logs make it easy to audit who logged in and when, and to correlate DHCP server activity with other devices.
- Accurate NTP-based time-stamps are crucial for forensics and incident timelines.
- Helps detect suspicious login patterns (e.g. many logins at odd hours).

5. Traffic Visibility with NetFlow on Service and Management Links

Function:

Provide visibility into traffic hitting the DHCP server and its management interface.

How it works:

- A NetFlow record, exporter, and monitor are configured, same style as your router and cores.
- The monitor is applied on Gi0/0/0 (service interface) and Gi0/1/1 (management interface).
- Flow logs are exported to 192.168.90.10 on UDP 9996.

Example from configuration:

```

:
flow record NETFLOW-RECORD
match ipv4 source address
match ipv4 destination address
match transport source-port
match transport destination-port
match ipv4 protocol
collect counter bytes layer2 long
collect counter packets long
!
!
flow exporter NETFLOW-EXPORTER
destination 192.168.90.10
source GigabitEthernet0/0/0
transport udp 9996
!
!
flow monitor NETFLOW-MONITOR
exporter NETFLOW-EXPORTER
record NETFLOW-RECORD
!

```

```

interface GigabitEthernet0/0/0
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.80.4 255.255.255.240
negotiation auto

```

```

interface GigabitEthernet0/1/1
vrf forwarding Mgmt-vrf
ip flow monitor NETFLOW-MONITOR input
ip flow monitor NETFLOW-MONITOR output
ip address 192.168.16.18 255.255.255.0
negotiation auto

```

Benefits:

- Lets you see any suspicious traffic targeting the DHCP server (e.g. scanning, floods).
- Helps verify that only expected relays/clients are talking to the DHCP service.
- Integrates with your existing NetFlow collector to give a consistent view across the router, cores, and DHCP server.

6. Conclusion

In summary, the DHCP-Server has been secured so that it reliably supports address allocation without becoming a weak point in the network.

Excluded-address ranges protect key infrastructure IPs from accidental leasing, while per-VLAN DHCP pools ensure clients always receive the correct default gateway and trusted internal DNS server. This reduces the risk of IP conflicts and mitigates attacks that rely on redirecting users via rogue gateways or DNS.

At the same time, the underlying device is hardened with Mgmt-vrf separation, SSH-only remote access with local authentication, and shutdown unused interfaces, reducing both logical and physical attack surface. Centralised syslog, NTP, and NetFlow provide visibility and accurate, time-aligned records of activity

around the DHCP service. Collectively, these measures ensure that the DHCP-Server contributes to the overall defence-in-depth posture of the Qubit network rather than weakening it.

SSH Steps on user login

Steps on user login via jumphost

User can login to internal devices only via the SSH jumphosts, using the following steps and IPs:

Step 1 – SSH to Primary Jumphost (VPN Server)

From the user's workstation:

- a. Enter the ubuntu user password when prompted.
- b. You are now on the VPN/jumphost at 192.168.70.12.

```
ubuntu@vpn:~$ ssh ubuntu@192.168.70.12
ubuntu@192.168.70.12's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-143-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Nov 17 12:16:44 PM UTC 2025

System load:  0.08               Processes:            117
Usage of /:   32.1% of 13.67GB   Users logged in:     1
Memory usage: 7%                IPv4 address for ens18: 192.168.70.12
Swap usage:  0%

Expanded Security Maintenance for Applications is not enabled.

56 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

New release '24.04.3 LTS' available.
Run 'do-release-upgrade' to upgrade to it.
```

Step 2 – SSH to Proxmox Jumphost

From the first jumphost (192.168.70.12):

- a. Enter the root password.
- b. You are now on the Proxmox server at 192.168.70.13, which acts as the second-level jumphost.

```
ubuntu@vpn:~$ ssh root@192.168.70.13
root@192.168.70.13's password:
Linux pve 6.8.12-11-pve #1 SMP PREEMPT_DYNAMIC PMX 6.8.12-11 (2025-05-22T09:39Z) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Nov 18 03:39:53 2025 from 192.168.70.14
```

Step 3 – SSH to Network Device (Example: Switch S2)

From the Proxmox jumphost (192.168.70.13):

- a. Enter the shifan user password.
- b. At the device prompt, enter privileged mode if needed:

```
root@pve:~# ssh shifan@192.168.16.11
(shifan@192.168.16.11) Password:

S2>en
Password:
S2#
```

Special Implementation

As part of the lifelong learning requirement, our team went beyond the core syllabus and implemented three additional features: NetFlow, centralised Syslog, and a VPN/jumphost server. NetFlow and Syslog give us central visibility of traffic and security events across the router, cores and servers, supporting monitoring and incident investigation. The VPN/jumphost provides a controlled, authenticated SSH path into the network instead of direct access, further strengthening our overall defence-in-depth design.

1. VPN

Setup

Step 1 – Update your system

Run the apt command to install Ubuntu security updates:

```
sudo apt update  
sudo apt upgrade
```

Step 2 – Installing a WireGuard VPN server on Ubuntu

Now we got our server updates with the latest security patches. It is time for setting up a WireGuard VPN server on Ubuntu 20.04 server. Enter:

```
sudo apt install wireguard
```

Ubuntu install WireGuard using apt get command

Step 3 – Configuring WireGuard server

First we need to create a private and public key pair for the WireGuard server. Let us cd into /etc/wireguard using the cd command:

```
sudo -i  
# Make a new wireguard dir if not found using mkdir command #  
mkdir -m 0700 /etc/wireguard/  
cd /etc/wireguard/
```

Execute the following command:

```
umask 077; wg genkey | tee privatekey | wg pubkey > publickey
```

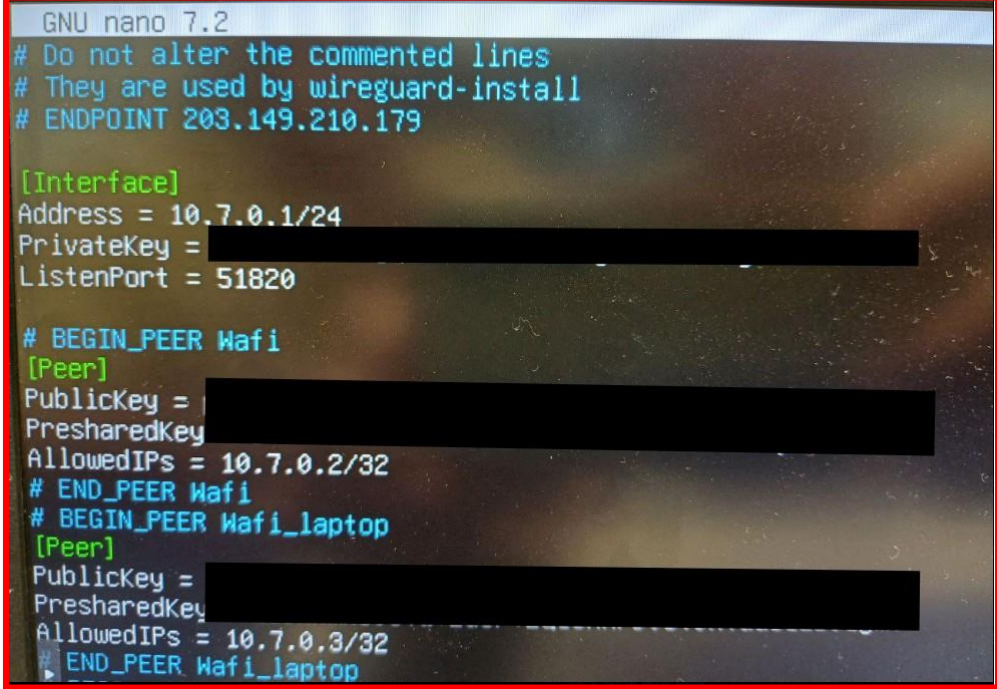
To view keys created use the cat command and ls command:

```
ls -l privatekey publickey  
cat privatekey  
## Please note down the private key ##  
cat publickey
```

Set Up WireGuard VPN on Ubuntu by Editing wg0.conf Edit or update the /etc/wireguard/wg0.conf file as follows:

```
sudo nano /etc/wireguard/wg0.conf  
## OR ##  
sudo vim /etc/wireguard/wg0.conf
```

Append the following config directives:



```
GNU nano 7.2  
# Do not alter the commented lines  
# They are used by wireguard-install  
# ENDPOINT 203.149.210.179  
  
[Interface]  
Address = 10.7.0.1/24  
PrivateKey = [REDACTED]  
ListenPort = 51820  
  
# BEGIN_PEER Wafi  
[Peer]  
PublicKey = [REDACTED]  
PresharedKey = [REDACTED]  
AllowedIPs = 10.7.0.2/32  
# END_PEER Wafi  
# BEGIN_PEER Wafi_laptop  
[Peer]  
PublicKey = [REDACTED]  
PresharedKey = [REDACTED]  
AllowedIPs = 10.7.0.3/32  
# END_PEER Wafi_laptop
```



```
# BEGIN_PEER Wafi
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.2/32
# END_PEER Wafi
# BEGIN_PEER Wafi_laptop
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.3/32
# END_PEER Wafi_laptop
# BEGIN_PEER shifan
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.4/32
# END_PEER shifan
# BEGIN_PEER abdillah
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.5/32
# END_PEER abdillah
```

```
# BEGIN_PEER nafis
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.6/32
# END_PEER nafis
# BEGIN_PEER saad
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.7/32
# END_PEER saad
# BEGIN_PEER adil
```

```
# BEGIN_PEER adil
[Peer]
PublicKey = [REDACTED]
PresharedKey = [REDACTED]
AllowedIPs = 10.7.0.8/32
# END_PEER adil
```

Turn on IPv4 and IPv6 forwarding. Append to a file with sudo as follows using the echo command:

```
echo 'net.ipv4.ip_forward=1' | sudo tee -a /etc/sysctl.d/10-wireguard.conf
echo 'net.ipv6.conf.all.forwarding=1' | sudo tee -a
/etc/sysctl.d/10-wireguard.conf
## Reload changes using the sysctl command ##
```



```
sysctl -p /etc/sysctl.d/10-wireguard.conf
```

Step 4 – Enable and start WireGuard service

Turn the WireGuard service at boot time using the systemctl command, run:

```
sudo systemctl enable wg-quick@wg0
```

Start the service, execute:

```
sudo systemctl start wg-quick@wg0
```

Get the service status, run:

```
sudo systemctl status wg-quick@wg0
```

Verify that interface named wg0 is up and running on Ubuntu server using the ip command:

```
sudo wg  
sudo ip a show wg0
```

Step 5 – Wireguard VPN client configuration

The procedure for installing and configuring a VPN client is the same as setting up the server. Let us install the client on an Ubuntu Linux:

```
sudo apt install wireguard
```

Next we need create VPN client config on Ubuntu/Debian/CentOS Linux desktop:

```
sudo sh -c 'umask 077; touch /etc/wireguard/wg0.conf'  
sudo -i  
cd /etc/wireguard/  
umask 077; wg genkey | tee privatekey | wg pubkey > publickey  
ls -l publickey privatekey
```

```
## Note down the privatekey ##  
cat privatekey
```

Edit the /etc/wireguard/wg0.conf file on your client side:

```
sudo nano /etc/wireguard/wg0.conf  
## OR ##  
sudo vim /etc/wireguard/wg0.conf
```

Append the following directives:

Enable and start VPN client/peer connection, run:

```
sudo systemctl enable wg-quick@wg0  
sudo systemctl start wg-quick@wg0  
sudo systemctl status wg-quick@wg0
```

Allow desktop client and Ubuntu server connection over VPN

We need to configure the server-side peer-to-peer VPN option and allow a connection between the client computer and the server. Let us go back to our Ubuntu server and edit wg0.conf file to add [Peer] (client) information as follows (type commands on your server box):

```
sudo systemctl stop wg-quick@wg0  
sudo vi /etc/wireguard/wg0.conf
```

Save and close the file. Next start the service again, run:

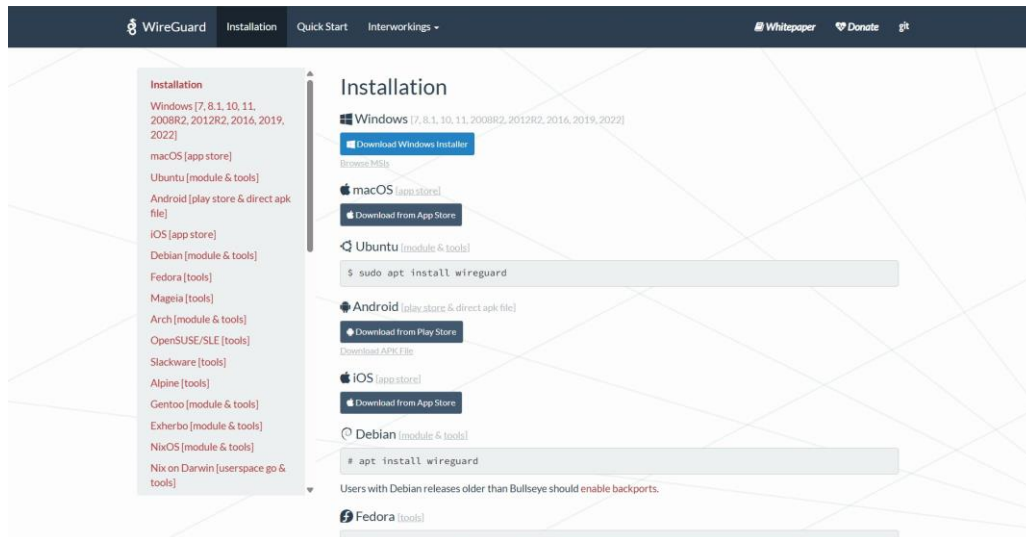
```
sudo systemctl start wg-quick@wg0
```

Step 6 – Verification

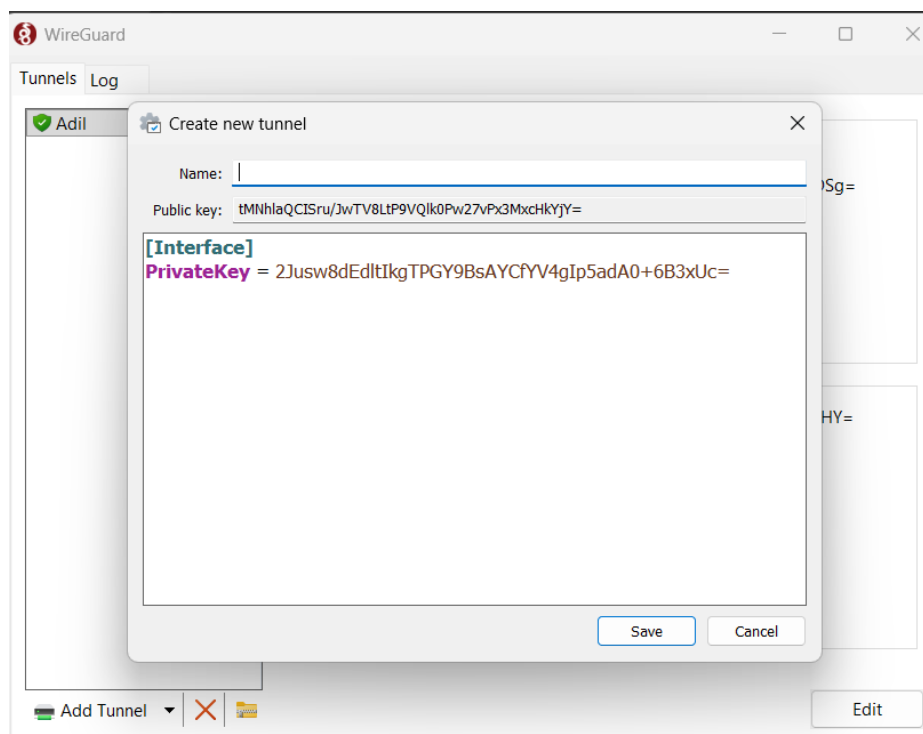
That is all, folks. By now, both Ubuntu servers and clients must be connected securely using a peer-to-peer VPN called WireGuard. Let us test the connection. Type the following ping command on your client machine/desktop system:

```
ping -c 4 10.7.0.1  
sudo wg
```

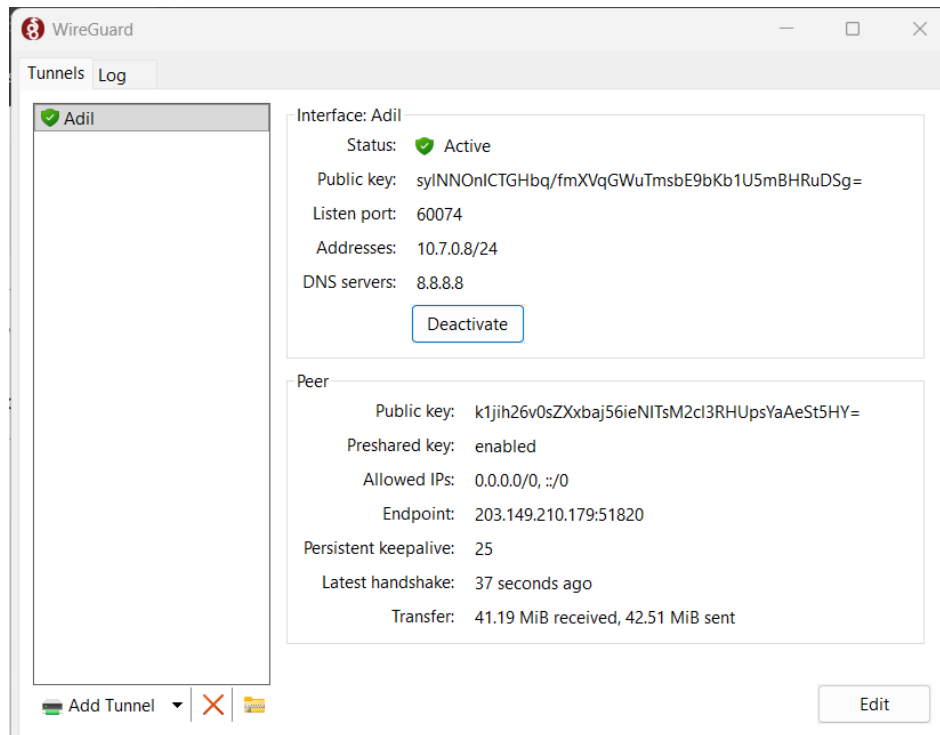
Step 7 – Download wireguard



Add tunnel in wireguard and copy paste the client configuration in the empty space:



Press Activate button:



Now the client is connected to the Jumphost directly. You can check by pinging the internal network in the topology:

```
C:\Users\adila>ping 192.168.30.1

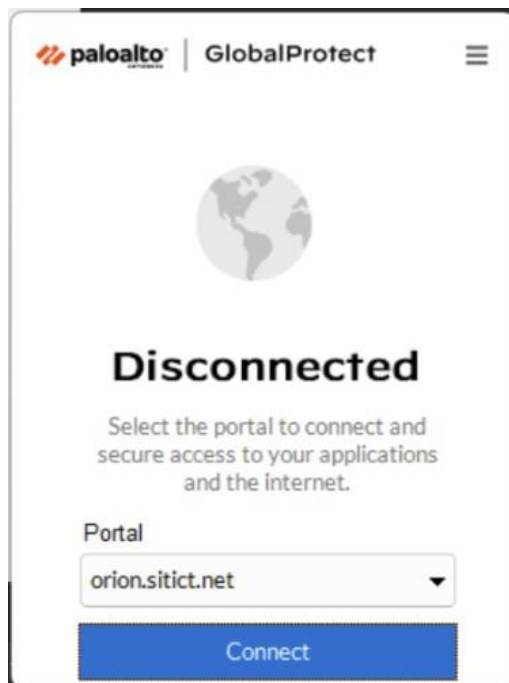
Pinging 192.168.30.1 with 32 bytes of data:
Reply from 192.168.30.1: bytes=32 time=12ms TTL=252
Reply from 192.168.30.1: bytes=32 time=17ms TTL=252
Reply from 192.168.30.1: bytes=32 time=7ms TTL=252
Reply from 192.168.30.1: bytes=32 time=4ms TTL=252

Ping statistics for 192.168.30.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 4ms, Maximum = 17ms, Average = 10ms

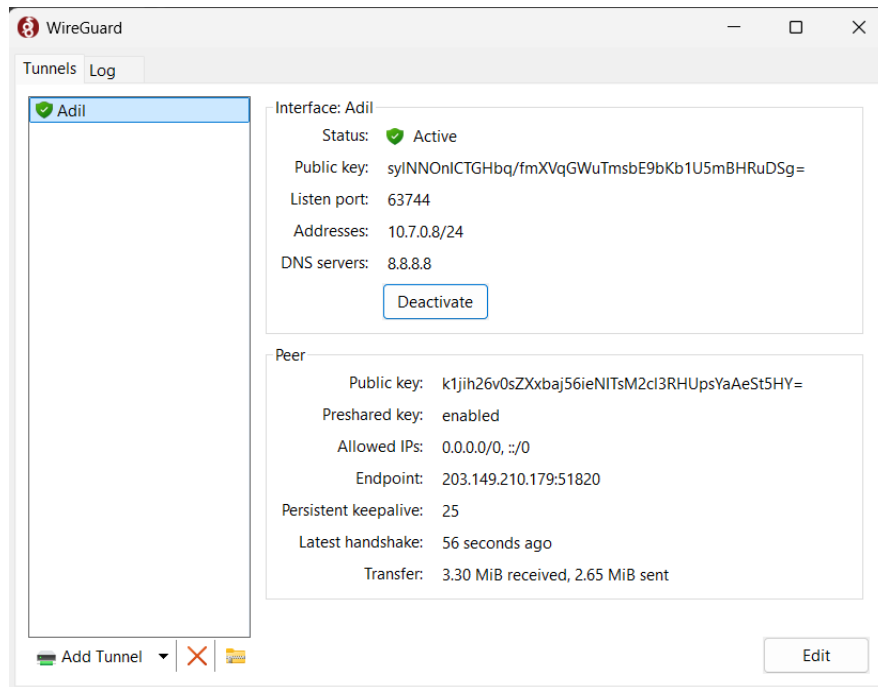
C:\Users\adila>ping 192.168.40.1

Pinging 192.168.40.1 with 32 bytes of data:
Reply from 192.168.40.1: bytes=32 time=4ms TTL=252
Reply from 192.168.40.1: bytes=32 time=15ms TTL=252
Reply from 192.168.40.1: bytes=32 time=26ms TTL=252
Reply from 192.168.40.1: bytes=32 time=6ms TTL=252
```

Jumphost SSH Steps



From users location, log in to the schools vpn, Paloalto so that they can connect to ICT_WIFI. Once they manage to log in, they can just activate the wireguard VPN to automatically enter the jumphost.



Once logged in wireguard user will automatically enter jumphost and they can check through the different ip in ipconfig command:

```
Unknown adapter Adil:
```

```
Connection-specific DNS Suffix  . :  
IPv4 Address. . . . .           : 10.7.0.8  
Subnet Mask . . . . .           : 255.255.255.0  
Default Gateway . . . . .       : ::  
                                0.0.0.0
```

Conclusion

In summary, the additional WireGuard VPN was implemented not to replace SSH, but to strengthen access control in a shared lab environment. While SSH already provides encryption, the ICT-WIFI network is used by multiple teams, meaning any user on that network could attempt to reach the public jumphost IP and probe the SSH service. By placing a WireGuard VPN in front of the jumphost, only endpoints that possess the correct team-specific VPN keys are

able to reach the SSH port at all. This creates an extra security layer that combines network-level access control (VPN) with application-level authentication (SSH), aligning with defence-in-depth principles and reducing the attack surface on the management infrastructure.

2. Netflow

Function:

NetFlow is used to provide detailed visibility of IP traffic flows across key Layer 3 devices. While traditional interface counters only show how busy a link is, NetFlow records information such as source and destination IP address, ports, protocol, and the number of bytes and packets for each flow.

All flow records are exported to the SIEM server in VLAN 90 (192.168.90.10), which acts as the central NetFlow collector for analysis and long-term storage.

How NetFlow Works:

NetFlow is enabled on the main routing devices (e.g. the Internet edge router and core switches). For each of these devices:

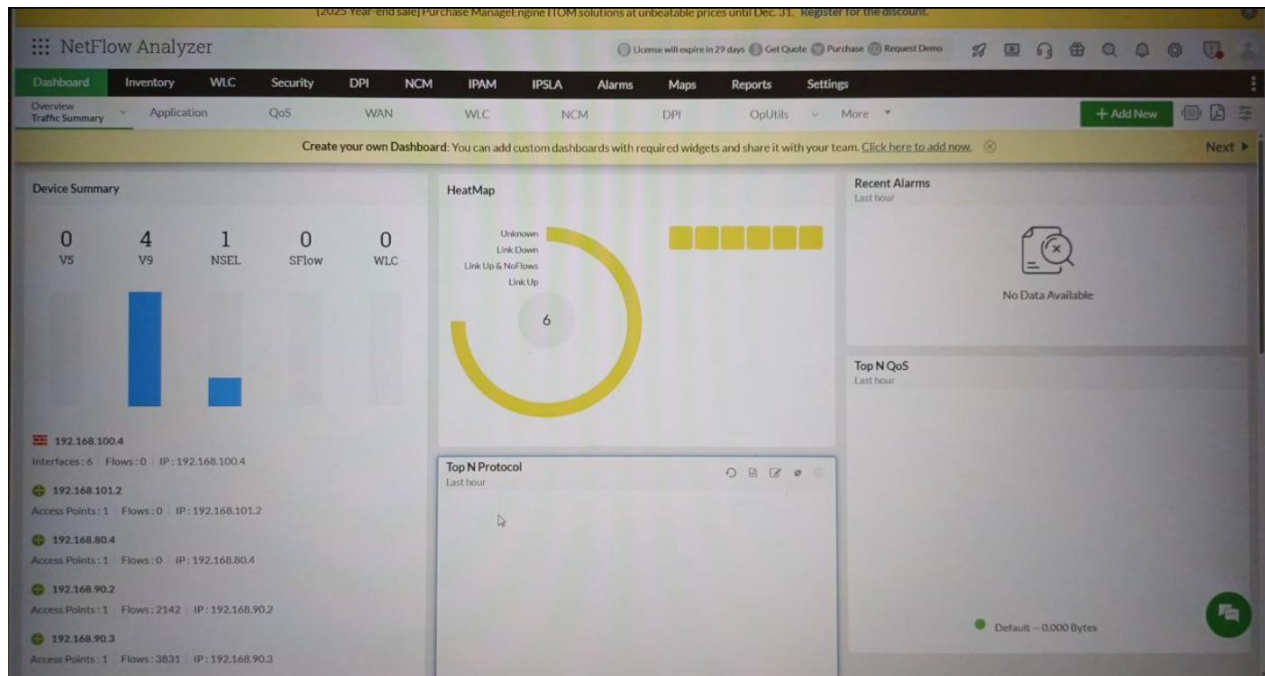
- A NetFlow exporter is configured to send flow records to the SIEM at 192.168.90.10, using a standard UDP port 9996 and the device's VLAN 90 management IP as the source address.
- A flow monitor is created and applied inbound and outbound on key routed interfaces (for example, the Internet-facing interface and the inter-VLAN/DMZ interfaces).
- The L2 access switch (L2 Switch 3) simply forwards this traffic within VLAN 90; it does not generate NetFlow itself. The SIEM, connected on Gi1/0/15 in VLAN 90 (192.168.90.0/24), receives and processes all exported flow data.

As user traffic passes through these monitored interfaces, the router or core switch builds a flow record for each unique conversation and periodically exports these records to the SIEM. The SIEM then presents dashboards such as top talkers, top applications, and unusual flows.

Benefits:

- Improved traffic visibility
 - Administrators can see which hosts and services consume the most bandwidth and which networks are communicating, instead of guessing from raw interface utilisation.
- Faster troubleshooting
 - When users report slow performance, NetFlow reports from the SIEM help quickly identify congestion points, abnormal traffic spikes, or misrouted flows.
- Enhanced security monitoring
 - Unusual patterns, such as many short connections to different destinations, sudden outbound spikes, or traffic to unexpected ports, can indicate scanning, malware, or DDoS activity. NetFlow therefore supports the overall defence-in-depth strategy alongside the firewall and ACLs.
- Capacity planning and trend analysis
 - Historical NetFlow data stored on the SIEM allows the team to track growth over time and plan link upgrades or QoS policies based on real traffic patterns.

Below is the screenshot from when we initially started and tested. We have received packets from the Cisco devices



Conclusion

We implemented NetFlow to see exactly what is happening on the network instead of guessing. With many VLANs, DMZ services and an Internet edge, simple interface counters are not enough. NetFlow gives us central, per-flow visibility on the SIEM so we can spot abnormal traffic, investigate incidents, and troubleshoot slowdowns quickly, while also using the historical data for capacity planning and tuning security policies.

3. Syslog

Function:

Syslog is used in the to collect and centralise log messages from routers, firewalls and switches. These messages include events such as interface up/down, configuration changes, login attempts and routing updates. Centralising them on a dedicated server allows the administrators to use the logs for monitoring, debugging and troubleshooting, especially when combined with accurate timestamps from NTP.

In this design, all infrastructure devices send their Syslog messages to the SIEM server in VLAN 90 (192.168.90.10), which acts as the Syslog collector.

How Syslog Works in This Design

Each key device (e.g. CORE-A, CORE-B, firewall FW1, edge router, DHCP/AAA servers) is configured as follows:

- Timestamping enabled
 - service timestamps log datetime msec
 - This adds date, time and milliseconds to every log message so that events from different devices can be correlated correctly on the SIEM.
 - Remote Syslog server defined
 - logging host 192.168.90.10
 - Devices send their Syslog messages over UDP port 520 to the SIEM in VLAN 90, using their management IP in VLAN 90 as the source interface.
 - Severity level tuned
 - logging trap informational (or an equivalent level between 4–6)
 - This ensures that important events (emergencies, alerts, critical, errors, warnings, notifications and informational messages) are sent, without flooding the SIEM with low-value debugging logs.
- lab3.5Ex - Configuring Syslog a...

L2 Switch 3 simply forwards traffic within VLAN 90; the actual Syslog export is done by the Layer 3 devices and security appliances. The SIEM then stores and displays these messages in dashboards and timelines, where they can be filtered by device, severity or time.

Benefits

Implementing Syslog with a central SIEM in VLAN 90 gives Qubit several advantages:

- Centralised visibility
 - All critical events from routers, switches and firewalls are collected in one place (192.168.90.10), instead of being scattered across device buffers.
- Faster troubleshooting
 - When an issue occurs (e.g. link flaps, routing changes, failed logins), engineers can quickly review the correlated logs on the SIEM to see what happened, where and when.
- Stronger security monitoring
 - Security-relevant events such as ACL drops, VPN failures or repeated login attempts are captured centrally, supporting incident detection and investigation as part of the overall defence-in-depth strategy.
- Audit and compliance
 - Archived Syslog messages provide an audit trail of configuration changes and operational events, which is useful for post-incident review and any future compliance requirements.

Conclusion:

In our lab design, all infrastructure devices are configured to send Syslog messages to a central SIEM at 192.168.90.10, which runs Syslog Watcher Manager (free edition). The free version is limited to 3 originators and 5,000

messages per hour, so we had to be intentional about which logs we collect and when. Practically, this means we prioritise core security and infrastructure devices (e.g. edge router, firewall, one core switch) as the primary originators, and we selectively enable/disable logging on the network side when we need to focus on specific devices or tests. By temporarily turning off logging on less critical devices and only enabling it when we want to inspect their behaviour, we stay within the 3-originator limit while still being able to observe all devices when required.

Similarly, the 5,000-logs-per-hour cap forces us to reserve logging capacity for the most important event types. In configuration, we therefore tune the logging level (e.g. logging trap informational) and avoid debug-level noise, so that interface state changes, routing updates, security events, and login attempts are recorded, but low-value debug messages are not. Even with these constraints, the combination of central Syslog collection + NTP-synchronised timestamps still gives us a meaningful, correlated view of what is happening across the network, and demonstrates a realistic SIEM-style logging architecture within the limits of a free tool.

3. NTP & JumpHost

Function:

In our design, the JumpHost and NTP server are combined on a single Ubuntu VM hosted on Proxmox. This VM has:

- 192.168.70.13 in the DMZ subnet 192.168.70.0/24 → used as the SSH/VPN JumpHost, and
- 192.168.16.100 in the management subnet 192.168.16.0/24 → used as the central NTP server for all infrastructure devices.

The primary function of this design is twofold:

1. Provide a single, tightly controlled entry point into the management network via the JumpHost.

2. Offer a single, trusted and internal time source (NTP) so that routers, switches and servers share a consistent clock for logging and security monitoring.

How NTP & JumpHost work together:

Although NTP and the JumpHost offer different services, they are deliberately integrated on the same VM to strengthen the management and monitoring plane:

1. Dual-homed management VM

- The Ubuntu VM is DMZ-facing at 192.168.70.13 and management-facing at 192.168.16.100.
- From the outside/ICT-WIFI, administrators first connect to the DMZ IP on the JumpHost (via VPN + SSH), never directly to any network device.
- From the management side, all network devices (R1, CORE-A, CORE-B, DHCP-Server, L2 switch) reach the NTP service using 192.168.16.100, usually via Mgmt-vrf.

2. Secure admin access path

- Admin workflow: remote user → VPN → JumpHost (192.168.70.13) → SSH to management IPs (192.168.16.x).
- All configuration changes are executed from sessions that originate at the JumpHost, so its own system logs record who connected and when.

3. Unified time source for all logs

The JumpHost/NTP VM serves as the authoritative internal clock. Commands such as:

```
ntp server vrf Mgmt-vrf 192.168.16.100
```

ntp logging

On routers and switches ensure they synchronise with the same NTP source. When an admin logs in via the JumpHost and makes a change on a device, the timestamps in:

- the JumpHost's SSH/VPN logs, and
 - the router/switch Syslog entries
- are all aligned to the same NTP time from 192.168.16.100.
4. Support for monitoring and forensics
- Because NTP keeps clocks in sync, events from the JumpHost, network devices, NetFlow exports and Syslog on the SIEM can be correlated precisely.
 - This means an investigator can trace: *"Admin X connected to JumpHost at 10:05:12, logged into CORE-A at 10:05:30, and the ACL change occurred at 10:05:45"* on a single coherent timeline.

Benefits:

- Strong management-plane control. All administrative access must pass through the JumpHost at 192.168.70.13, instead of going directly to routers and switches. This:
 - reduces the exposed attack surface,
 - centralises where admin access is monitored, and
 - allows the team to enforce extra controls (e.g. VPN, key-based auth, limited user accounts) on a single server.
- Consistent and reliable timestamps. With NTP centralised at 192.168.16.100, all infrastructure devices share the same time. This is essential for:

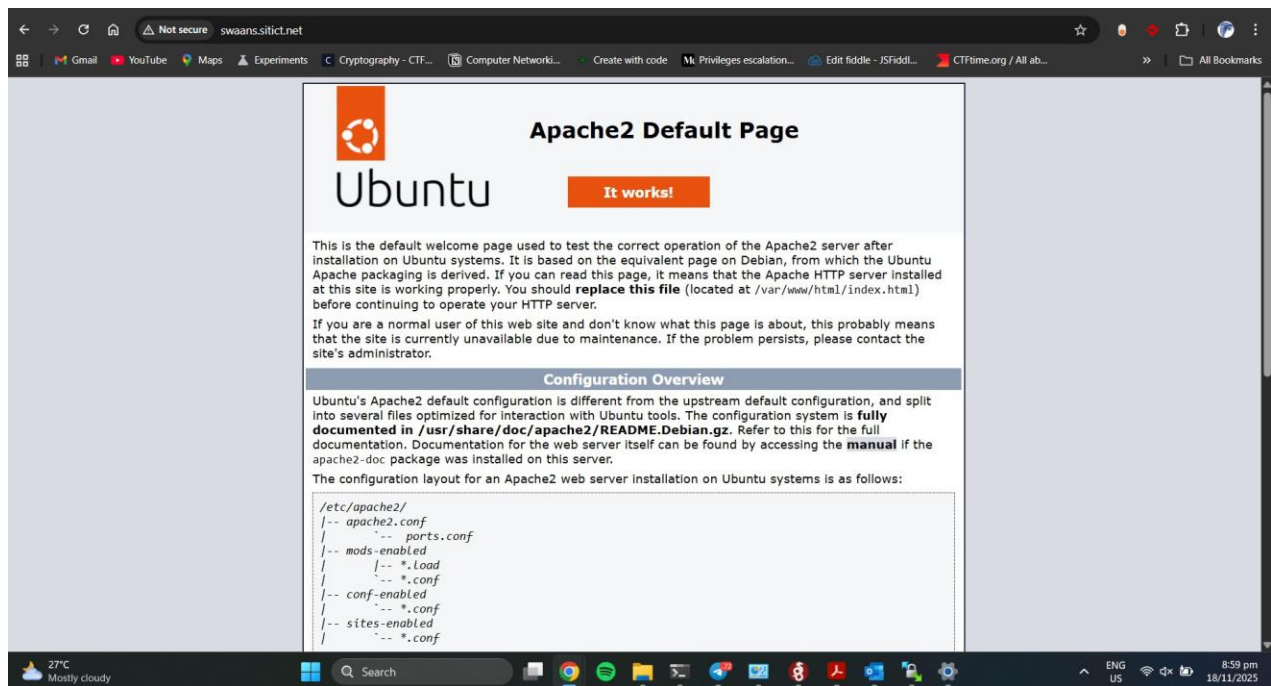
- accurate incident timelines,
 - correct certificate and VPN validity checks, and
 - reliable log retention and rotation.
- Better auditability and accountability
Because admins always enter through the JumpHost, actions can be traced end-to-end:
 - JumpHost SSH/VPN logs show who logged in and from where,
 - device logs (with NTP time) show what was changed,
 - and NetFlow/Syslog show what traffic occurred afterwards. This produces a clear audit trail that supports both operational troubleshooting and security audits.
- Logical separation with simple infrastructure. Using one Proxmox VM with two interfaces is simpler than deploying multiple servers, but still maintains a clear logical separation:
 - DMZ IP (192.168.70.13) is for remote admin entry,
 - Management IP (192.168.16.100) is for infrastructure time sync. This keeps the management subnet hidden from direct external access while still being reachable to devices for NTP.
- Improved incident response and troubleshooting. When something goes wrong (e.g. misconfiguration, suspected compromise, performance issue), having time-aligned logs from JumpHost and all devices allows the team to:
 - quickly reconstruct event sequences,
 - identify the exact change that triggered a problem, and

- 0 cross-check admin activity against anomalies seen in NetFlow and Syslog.

Conclusion:

The combined NTP and JumpHost architecture turns a single Ubuntu VM on Proxmox into a key component of the Qubit management and security framework. The JumpHost at 192.168.70.13 enforces a controlled, audited path for all administrative access, while the NTP service at 192.168.16.100 provides a consistent time base for every router, switch and server. Working together, they enhance defence in depth, auditability and operational visibility, ensuring that management actions and network events can be monitored, correlated and investigated with confidence.

4. DNS & Web Server



Function:

The DNS server (192.168.70.11) and Web server (192.168.70.10), both located

in the DMZ subnet 192.168.70.0/24, work together to provide a secure and consistent web presence for swaans.sitict.net.

- DNS at 192.168.70.11 is the authoritative name server for the domain.
- The Web server at 192.168.70.10 hosts the public website (e.g. www.swaans.sitict.net).
Externally, both servers are published via static NAT to public IPs, while internal clients reach them directly using private addresses.

How DNS & Web work together:

1. DMZ hosting with static NAT
 - Web server: 192.168.70.10 → public IP 203.149.210.177
 - DNS server: 192.168.70.11 → public IP 203.149.210.178. Static NAT on the edge router ensures Internet users can reach the public website and authoritative DNS while both servers remain in the protected DMZ.
2. DNS records pointing to the Web service. On the DNS server (192.168.70.11), we host the zone swaans.sitict.net, including records such as:
 - www.swaans.sitict.net → Web server IP (internal or public, depending on view)
 - swaans.sitict.net (root) → Web server IP
For external clients, these records return the public IP (e.g. 203.149.210.177), which is then translated by NAT back to 192.168.70.10.
For internal clients, the DNS server can return the internal DMZ IP (192.168.70.10), avoiding hairpinning through the Internet edge.
3. Internal vs external (split-view) behaviour

- Internal users (e.g. VLAN 10/20/30/.../90) receive 192.168.70.11 as DNS via DHCP. When they browse to `www.swaans.sitict.net`, DNS resolves the name to the DMZ address (192.168.70.10), so traffic stays inside the Qubit network.
- External users resolve `www.swaans.sitict.net` via public DNS, which ultimately reaches 203.149.210.177 (NAT to 192.168.70.10). They never see the internal addressing, only the public IP.

NAT-aware design. The router has:

`no ip nat service dns tcp no`

`ip nat service dns udp`

This is to prevent automatic DNS rewriting. This ensures that the DNS server controls exactly which IPs are returned (internal vs external), and NAT only translates packets, not DNS payloads. This keeps DNS + Web behaviour predictable and easier to troubleshoot.

Benefits:

- Clean, user-friendly access to the website. Users (inside and outside) simply type `swaans.sitict.net` or `www.swaans.sitict.net` without needing to remember IP addresses. DNS transparently directs them to the right Web server IP based on where they are.
- Security through DMZ isolation. Both DNS (192.168.70.11) and Web (192.168.70.10) live in the DMZ, not directly on the internal LAN. Firewalls and ACLs control exactly which ports are exposed:
 - Internet → Web (HTTP/HTTPS)
 - Internet → DNS (UDP/TCP 53)
 Internal networks can still reach these services, but internal addressing and management subnets remain hidden.
- Split-view DNS for privacy and efficiency. Internal clients can be given internal DMZ IPs for the web service, while external clients only see public

addresses. This reduces information leakage about internal topology and avoids unnecessary traffic leaving and re-entering the network.

- Easier management and scaling. Using DNS as the “front door” for the web service means future changes (e.g. moving the website to another DMZ host or load balancer) only require updating DNS records, not reconfiguring every client.

Conclusion:

By tightly integrating the DNS server (192.168.70.11) with the Web server (192.168.70.10) in the DMZ, the Qubit design delivers a secure, NAT-aware, and user-friendly web presence for swaans.sitict.net. DNS provides the naming and split-view logic, while the Web server delivers the actual content, both shielded behind the firewall and published via static public IPs. This approach improves usability for users, protects internal addressing, and follows best practices for hosting Internet-facing services in a DMZ.

6. TACACS+ (AAA) Server

Function:

The main function of TACACS+ in this design is centralised AAA (Authentication, Authorisation and Accounting) for device administration:

- Authentication – verify the identity of administrators (e.g. admin, Netroot, Netadmin) when they log in to network devices.
- Authorisation – assign the correct privilege level (e.g. level 7 or level 15) based on their role or group membership (level7, level15 groups).
- Accounting – log all admin logins and, if configured, their commands into an accounting file (/var/log/tac_plus.acct) for auditing and forensic purposes.

How TACACS+ Works in This Design:

1) Admin initiates device access

An administrator connects to a router, switch or firewall (e.g. via SSH). The device is configured to use TACACS+ as the primary AAA method (e.g. `aaa authentication login default group tacacs+ local`).

2) Device contacts the TACACS+ server

- The network device sends an authentication request to the TACACS+ server using the configured shared key (key = "secret123").
- Communication between the device and TACACS+ server is protected using this key so that credentials and AAA messages cannot be easily tampered with.
1622b6bf-8cc4-4eee-8a42-723ad3f...

3) Authentication and privilege assignment

- The TACACS+ server checks the username and password against the user database defined in the config:
 - user = admin with priv-lvl = 15 (full access).
 - user = Netroot assigned to group = level15 with priv-lvl = 15.
 - user = Netadmin assigned to group = level7 with priv-lvl = 7.
1622b6bf-8cc4-4eee-8a42-723ad3f...
 - If credentials are correct, the server replies with an ACCEPT and the privilege level the user should get on the device (for example, full priv 15 for senior engineers, priv 7 for junior admins).
- ### 4) Authorisation of commands (optional / per policy)
- Depending on policy, TACACS+ can be used not just for login, but also to control which commands an admin can run based on their group or privilege level.

- For example, a level 7 user may be allowed to view configuration and run show/debug commands, while level 15 users can also modify configuration.

5) Accounting and logging

- All login attempts and (optionally) commands are logged to the accounting file specified in the config (accounting file = "/var/log/tac_plus.acct").
- These logs provide a timeline of who logged into which device, when, and what they did.
1622b6bf-8cc4-4eee-8a42-723ad3f...

6) Fallback to local authentication

- On the devices, the AAA configuration typically uses group tacacs+ local, so if the TACACS+ server is unavailable, the device falls back to local user accounts to avoid locking out all admin access.

Benefits:

Using TACACS+ for device administration in this network provides several key benefits:

- Centralised control of admin accounts
 - All admin accounts and their privileges are defined once on the TACACS+ server rather than separately on every router, switch and firewall.
 - Adding, removing or modifying an admin (e.g. changing Netadmin from level 7 to level 15) only requires editing the TACACS+ config, not touching dozens of devices.
1622b6bf-8cc4-4eee-8a42-723ad3f...
- Role-based access and least privilege

- Groups such as level7 and level15 allow admins to be given just the level of access they need.
- Junior admins (e.g. Netadmin) can be restricted to monitoring and basic operations (priv 7), while senior engineers (admin, Netroot) can have full configuration rights (priv 15).
1622b6bf-8cc4-4eee-8a42-723ad3f...
- Improved security over shared enable passwords
 - Instead of one shared enable password for all admins, each person has their own username and password, plus an enable secret stored securely on the TACACS+ server.
 - If an admin leaves, their account can be disabled centrally without changing passwords on every device.
- Strong accountability and audit trail
 - Because TACACS+ logs all authentication and (optionally) command usage to /var/log/tac_plus.acct, it is possible to see exactly which user made which change and when.
 - This is essential for troubleshooting, incident response, and compliance.
- Consistent policy across the network
 - All infrastructure devices (core switches, distribution switches, firewall, routers) enforce the same AAA policy, ensuring a uniform security posture across the management plane.
- Supports defence-in-depth
 - TACACS+ secures the management plane of the network, complementing other controls such as firewalls, access control lists

and VLAN segmentation.

- Even if someone reaches a device management interface, they still need valid TACACS+ credentials and will be restricted to their assigned privilege level.

Credentials

Login to Jumphost private ip:

Username: root Password:

Student@s1t

Command: ssh root@192.168.70.13

Login to admin (privilege 7):

Username: Netadmin

Password: Swaans11! En

pass: saad

Command: ssh Netadmin@192.168.16.11

Login to root (privilege 15)

Username: Netroot Password:

Swaans69!

En pass: saad

Command: ssh Netroot@192.168.16.11

Login to firewall (Netadmin):

ssh -oHostKeyAlgorithms+=ssh-rsa -oPubkeyAcceptedAlgorithms+=ssh-rsa

Netadmin@192.168.16.16

Ssh pass: Swaans11! En

pass: saad

Login to firewall (Netroot):

ssh -oHostKeyAlgorithms+=ssh-rsa -oPubkeyAcceptedAlgorithms+=ssh-rsa

Netadmin@192.168.16.16

Ssh pass: Swaans69! En

pass: saad

Accounts:

username Netadmin privilege 7 secret Swaans11! username

Netroot privilege 15 secret Swaans69!